

Daily Vulnerability Report - 2026-10-03

Window (UTC): 2026-10-02T06:53 to 2026-10-03T06:53 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-10-03 06:54:26 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
497	467	28	2	2	33	210	170	90	15

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103956	New	10.0	CRIT				Missing authentication for critical function in the authentication dependency in Loom for AWS before 1.6.1 allowed remote actors to obtain super-admin authority over the agent control plane, including registering tool servers, reading stored integration credentials, and rewriting the IAM role policies attached to managed agent roles, via any request to the application API in...
CVE-2026-82041	New	9.9	CRIT				UTMStack before 11.2.16 contains a missing authorization vulnerability in UTMIncidentCommandWebsocket.processCommand(), the handler mapped to the /command/{hostname} STOMP destination, where no role check or command allowlist is applied before forwarding supplied commands. Any authenticated user, regardless of role, can send arbitrary operating-system commands over gRPC to a...
CVE-2026-90970	New	9.9	CRIT				GitLab has remediated a vulnerability in the GitLab AI Gateway component affecting all versions of the AI Gateway from 18.1.6 before 19.2.4, 19.3 before 19.3.2, and 19.4 before 19.4.1 that, under certain conditions, could have allowed an authenticated user with Duo Agent Platform access to escape the prompt template sandbox via a specially crafted flow configuration, resulti...
CVE-2026-93698	New	9.9	CRIT		0.005		Insufficient validation allows arbitrary commands to be executed via the Multilang adminbin.
CVE-2023-54405	New	9.8	CRIT				H3C CVM, the Cloud Virtualization Management component of the H3C CAS cloud platform, contains an unauthenticated arbitrary file upload vulnerability in the /cas/fileUpload/upload endpoint that allows remote attackers to write arbitrary files by manipulating the caller-supplied token parameter without restricting path traversal or file type. Attackers can exploit the path tr...
CVE-2026-104846	New	9.8	CRIT				Seroval facilitates JS value stringification, including complex structures beyond JSON.stringify capabilities. From 0.12.0 until 1.6.2, fromJSON deserialization of a fulfilled Promise control node can pass a plugin-produced callable-bearing thenable to a native Promise resolver. ECMAScript thenable assimilation then invokes the callable unexpectedly, allowing attacker-contro...
CVE-2026-19652	New	9.8	CRIT				The Divi Membership plugin for WordPress is vulnerable to Privilege Escalation in versions up to, and including, 2.2.0. This is due to the `dmem_form_submit_handler()` function determining the new user's role by iterating all WordPress roles and calling `password_verify()` against an attacker-controlled bcrypt hash supplied in the `form_id` POST parameter, with no validation...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82042	New	9.8	CRIT				UTMStack before 11.2.16 contains an authentication bypass vulnerability that allows remote attackers to gain full administrative API access by presenting a valid Utm-Internal-Key header matching the INTERNAL_KEY environment variable value, which the InternalApiKeyFilter accepts for any endpoint without path restriction, constant-time comparison, rate limiting, or audit loggi...
CVE-2026-94541	New	9.8	CRIT		0.005		The WPMobile.App – Android and iOS App Builder plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 11.82 This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to exfiltrate password-reset URLs for arbitrary users, including administrato...
CVE-2026-97637	New	9.8	CRIT		0.006		The JSON API Auth plugin for WordPress is vulnerable to Authentication Bypass via Cached Session Cookie Disclosure in all versions up to, and including, 3.1.2. The vulnerability exists because the required PI-Media/json-api parent plugin caches controller dispatch results in transients keyed solely by URI and query string, ignoring HTTP method and POST body; this causes the ...
CVE-2026-103628	New	9.6	CRIT				Out of bounds write in WebGL in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-104848	New	9.5	CRIT				Tinypool is a minimal Node.js worker thread pool implementation. Prior to 2.1.1.1, Tinypool constructs ThreadPool.options from a normal options object and reads the execArgv and env worker options in dist/index.js, allowing values inherited from a polluted Object.prototype to be copied into own properties and passed to worker_threads.Worker. An attacker who can first pollute e...
CVE-2026-104849	New	9.5	CRIT				Tinypool is a minimal Node.js worker thread pool implementation. Prior to 2.1.2, Tinypool reads filename from a caller-supplied options object in pool.run(task, options) without requiring an own property, so a polluted Object.prototype.filename can replace the intended worker module. Applications are affected only when they pass their own second-argument options object to po...
CVE-2026-105080	New	9.4	CRIT				In ConvertX before 0.19.0, converters/calibre.ts does not block recipe files, and instead passes them to the ebook-convert program from Calibre. This affects executable code in a .recipe or .downloaded_recipe file.
CVE-2026-75937	New	9.4	CRIT				A specially crafted HTTP POST request to the web administration interface allows an unauthenticated attacker to execute arbitrary operating system commands with root privileges on the affected device. Disable the web server when not configuring the device.
CVE-2026-86325	New	9.4	CRIT				A stack-based buffer overflow vulnerability exists in protocol gateways' account management interface. The vulnerability is caused by insufficient length validation of the `account_name` parameter when processing account management requests. An attacker authenticated as a read-only user to the web management interface could supply a specially crafted account name that exceed...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104019	New	9.3	CRIT				OS command injection in the Studio Space startup validation script in Amazon SageMaker Distribution 2.x before 2.14.12, 3.x before 3.9.12, 4.0.x before 4.0.11, 4.1.x before 4.1.11, 4.2.x before 4.2.8, 4.3.x before 4.3.5, and 4.4.x before 4.4.3, as used by Amazon SageMaker Unified Studio, might allow an authenticated remote user with project contributor permissions to execute...
CVE-2026-104610	New	9.3	CRIT				A security vulnerability has been detected in Tenda HG7, HG9 and HG10 300001138_en_xpon. This impacts the function boaGetVar of the file /boaform/formLoopBack of the component Boa Web Server. Such manipulation of the argument Ethtype leads to stack-based buffer overflow. The attack can be executed remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-84411	New	9.3	CRIT				The web management service in affected RouterOS versions contains an integer underflow in its HTTP request body handling that is reachable before authentication. This can be leveraged by an unauthenticated network attacker to achieve arbitrary code execution as root, or to cause a denial of service, using a single crafted request.
CVE-2026-95102	New	9.3	CRIT				WebSocket endpoints lack proper authentication mechanisms, enabling attackers to impersonate charging stations. As a result, attackers can exploit this weakness to gain unauthorized access to sensitive data or perform unauthorized actions. Given that no authentication is required, this can lead to privilege escalation and potentially compromise the security of the entire sys...
CVE-2026-104467	New	9.2	CRIT				YesWiki before 4.6.7 contains an authorization bypass vulnerability in ApiService::isAuthorized() that allows unauthenticated attackers to call admin-only API routes when public API mode is enabled. Attackers can send requests to endpoints like api/ci/update_config and api/archives to overwrite configuration and list, download, or delete backup archives.
CVE-2026-83632	New	9.2	CRIT				Allocation of resources without limits or throttling, Integer overflow or wraparound, Heap-based buffer overflow vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-91135	New	9.2	CRIT				Heap-based buffer overflow vulnerability in Apache Thrift C++ THeaderTransport. When an application enables the ZLIB transform for the frames it sends, THeaderTransport::transform() copies the compressed frame into the write buffer without making sure it fits. Data that does not compress, such as content a remote peer supplied, grows under compression, so the copy writes ...
CVE-2026-103648	New	9.1	CRIT				Path traversal in image-downloader 4.3.0 allows an attacker who can control the download URL to cause downloaded response data to be written outside the configured destination directory.
CVE-2026-63569	New	9.1	CRIT		0.004		Improper input validation in DHAgreement.CalculateAgreement (MTI/A0 two-pass Diffie-Hellman) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an on-path attacker to make the local party compute an agreed value the attacker already knows, defeating the key authentication MTI/A0 is meant to provide. It also allows a malicious peer to learn the local static pri...
CVE-2026-93029	New	9.0	CRIT		0.004		There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Manage SSL Hosts interface.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93697	New	9.0	CRIT		0.004		There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Mass Modify Accounts interface.
CVE-2026-103622	New	8.8	HIGH				Use after free in SVG in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103625	New	8.8	HIGH				Type confusion in V8 in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-104462	New	8.8	HIGH				YesWiki before 4.6.7 contains an SQL injection vulnerability in the Bazar nuagetag action, which concatenates the unescaped tags attribute into a raw SQL IN clause. Attackers with page-write access (unauthenticated on default installs) can embed a nuagetag tag ending in a backslash to break quote parity and inject a UNION subquery, exfiltrating password hashes and arbitrary ...
CVE-2026-104464	New	8.8	HIGH				YesWiki before 4.6.7 contains a server-side request forgery vulnerability that allows unauthenticated attackers to make server-side GET requests by supplying an unvalidated actor URL to the Bazar abonnements sync action. Attackers can target internal hosts or cloud metadata endpoints and chain attacker-controlled outbox first/next links, with fetched responses stored as read...
CVE-2026-104851	New	8.8	HIGH				fsspec is a specification and Python implementation framework for filesystem interfaces. From 0.9.0 until 2026.6.0, fsspec.implementations.reference.ReferenceFileSystem evaluates fields from Kerchunk reference JSON documents through unrestricted jinja2.Template(...).render(...) calls in _process_references1._render_jinja, _process_templates, and _process_gen in fsspec/implem...
CVE-2026-39718	New	8.8	HIGH				Cross-Site Request Forgery (CSRF) vulnerability in Webriti Wallstreet wallstreet allows Cross Site Request Forgery.This issue affects Wallstreet: from n/a through 2.8.6.
CVE-2026-80298	New	8.8	HIGH		0.004		Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in HAVELSAN Inc. Sef - AI Chatbot Platform allows SQL Injection. This issue affects Sef - AI Chatbot Platform: before 2.1. NOTE: The vendor was contacted and it was learned that the product is not supported.
CVE-2026-82039	New	8.8	HIGH				UTMStack before 11.2.16 contains a SQL injection vulnerability in UtmAssetGroupService.searchQueryBuilder() that allows authenticated attackers to inject arbitrary SQL by supplying malicious assetType and groupName values that are inserted unsanitized into a native PostgreSQL query via String.format(). Attackers can exploit the GET /api/utm-asset-groups/searchGroupsByFilter ...
CVE-2026-92536	New	8.8	HIGH				The Paid Membership Plugin, Ecommerce, User Registration Form, Login Form, User Profile & Restrict Content – ProfilePress plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 4.17.4 via the get_user_profile_structure. This makes it possible for authenticated attackers, with subscriber-level access and above, to extract ot...
CVE-2026-96940	New	8.8	HIGH				Weak authorization in Microsoft Exchange Server allows an authenticated attacker to elevate privileges over a network.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97644	New	8.8	HIGH				The Groundhogg — CRM, Newsletters, and Marketing Automation plugin for WordPress is vulnerable to Privilege Escalation via Contact Identity Rebinding in all versions up to, and including, 4.9 The vulnerability exists because the `create_contact` function in the v3 REST endpoint (`POST /gh/v3/contacts`) is gated solely by the `add_contacts` capability and forwards the full re...
CVE-2020-37278	New	8.7	HIGH				Weaver e-Bridge contains an unauthenticated arbitrary file read vulnerability that allows remote attackers to access arbitrary files on the host system by supplying a file: URL to the downloadUrl parameter of the saveYZJFile endpoint. Attackers can exploit this flaw to read sensitive files such as /etc/passwd or configuration and credential files, and the same endpoint's sup...
CVE-2026-103600	New	8.7	HIGH		0.003		Uncontrolled recursion in the ASN.1 parser (Asn1InputStream, Asn1StreamParser) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated attacker to cause a denial of service via a crafted ASN.1 encoding of deeply nested constructed elements (for example SEQUENCE inside SEQUENCE, in definite-length DER or indefinite-length BER form), because ...
CVE-2026-103603	New	8.7	HIGH		0.004		Memory allocation with excessive size value in the HSS/LMS signature code (HssPublicKeyParameters, HssSignature) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated attacker who can supply both an HSS public key and a signature to cause a denial of service through memory exhaustion via a public key encoding with an excessive level count...
CVE-2026-103604	New	8.7	HIGH		0.003		Inefficient algorithmic complexity in X.509 distinguished name string conversion (X509Name.ToString and IetfUtilities.ValueToString) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated attacker to cause a denial of service through CPU exhaustion via a certificate, CRL, certification request or other structure whose name contains a long ...
CVE-2026-104410	New	8.7	HIGH				SiYuan before 3.8.5 contains an information disclosure vulnerability that allows publish readers to read password-protected and publish-disabled database rows via the /api/export/preview endpoint. Attackers can request an export preview of a public document embedding a database view to obtain protected rows' primary-key text and cell values.
CVE-2026-104422	New	8.7	HIGH				The block sync download path in Zebra (zebrad) before 6.3.0 reads a block's height from its unvalidated coinbase scriptSig and drops blocks that appear too far behind the tip before consensus validation, without penalizing the supplying peer. Because V5 transaction IDs exclude the scriptSig, a malicious peer can repeatedly serve a canonical block whose coinbase claims height...
CVE-2026-104423	New	8.7	HIGH				Zebra (zebrad) before 6.2.1 contains an asymmetric resource consumption vulnerability that allows unauthenticated peers to stall block verification by pushing V6 mempool transactions with invalid Halo2 proofs. Attackers can flood the shared unprioritized Halo2 verification queue with zero-fee transactions carrying zero-filled Orchard and Ironwood proofs, causing nodes to fal...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104430	New	8.7	HIGH				Zebra zebra4 4.5.0 and zebra-script 7.0.0 count P2SH redeem script signature operations in legacy mode rather than zcashd's accurate P2SH mode, overcounting CHECKMULTISIG preceded by OP_1 through OP_16 as 20 sigops and causing a consensus divergence. Remote attackers can broadcast P2SH spends using low-threshold multisig redeem scripts so that a block zcashd accepts exceeds ...
CVE-2026-104431	New	8.7	HIGH				Zebra before 6.0.0 contains a denial of service vulnerability that allows unauthenticated peers to stall Tokio workers by submitting mempool transactions requiring expensive synchronous script verification. Attackers can send non-standard high-sigop P2SH transactions that reach CachedFfiTransaction::is_valid() before standardness checks, saturating the verifier buffer and re...
CVE-2026-104438	New	8.7	HIGH				YesWiki before 4.6.7 contains a missing authorization vulnerability in the listpagestag and includepages actions of the tags tool, which enumerate pages without applying read-ACL filtering. Unauthenticated or unprivileged attackers can embed these actions with a chosen tag or page name to disclose the names and body-derived titles of ACL-restricted pages.
CVE-2026-104460	New	8.7	HIGH				YesWiki before 4.6.7 contains a blind SQL injection vulnerability in the {{newtextsearch}} action because Bazar list option ids are concatenated into SQL REGEXP/LIKE clauses in actions/newtextsearch.php without escaping. Anonymous attackers can plant a malicious option id in an anonymously editable Bazar list and use search requests as a boolean oracle to read arbitrary data...
CVE-2026-104472	New	8.7	HIGH				YesWiki before 4.6.7 contains a missing authorization vulnerability in the attachment download handler that allows unauthenticated attackers to bypass page read ACLs. Attackers can request the download handler with a known page tag and file parameter to retrieve confidential attachments from read-restricted pages.
CVE-2026-16000	New	8.7	HIGH		0.003		Missing cryptographic step in the DSTU 7624 CCM mode implementation (KCcmBlockCipher) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who can observe encrypted messages of known or chosen content to forge ciphertexts with valid authentication tags, via messages encrypted without associated data. The cause is that the G1 block, which binds the no...
CVE-2026-17507	New	8.7	HIGH		0.003		In Bouncy Castle for Java before 1.86, the MLS implementation (org.bouncycastle.mls) holds RFC 9420's uint32 leaf_index in a signed int, so a wire value with the top bit set decodes to a negative number. That is a legitimate encoding rather than malformed input, and it must still decode, since the MLS interop test vectors round-trip the full range. GroupKeySet.SecretTree.has...
CVE-2026-61373	New	8.7	HIGH				Allocation of Resources Without Limits or Throttling vulnerability in Apache Thrift Java TSaslNonblockingServer. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-63566	New	8.7	HIGH		0.004		Memory allocation with excessive size value in the DTLS handshake reassembly (DtIsReliableHandshake, DtIsReassembler) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated DTLS peer to cause a denial of service through memory exhaustion via crafted handshake message fragments, because the reassembly buffer for each incoming handshake mess...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63568	New	8.7	HIGH		0.003		Allocation of resources without limits or throttling in the CMP/CRMF password-based MAC verifier (PKMacBuilder) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated attacker to cause a denial of service through CPU exhaustion via a CMP message or CRMF certificate request whose PBMPParameter declares a very large iteration count, because P...
CVE-2026-63571	New	8.7	HIGH		0.002		Improper verification of cryptographic signature in the attribute certificate path validator (PkixAttrCertPathValidator, also used by PkixAttrCertPathBuilder) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker to have a forged X.509 attribute certificate accepted as valid, and so obtain whatever roles or privileges an application grants on th...
CVE-2026-63574	New	8.7	HIGH		0.003		Memory allocation with excessive size value in the OpenPGP signature and user attribute subpacket parsers (SignatureSubpacketsParser.ReadPacket, UserAttributeSubpacketsParser.ReadPacket) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote, unauthenticated attacker who can supply a crafted OpenPGP public key, certificate or signature to cause a denial o...
CVE-2026-63772	New	8.7	HIGH				Allocation of Resources Without Limits or Throttling vulnerability in Apache Thrift go bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-66081	New	8.7	HIGH				Access of Uninitialized Pointer vulnerability in Apache Thrift c_glib bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-66837	New	8.7	HIGH				Stack-based Buffer Overflow, Integer Overflow or Wraparound vulnerability in Apache Thrift php bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-66858	New	8.7	HIGH				The protocol skip routine in several Apache Thrift bindings did not apply the binding's recursion limit, so a message that nests unknown fields deeply enough can exhaust the stack. Affected: the Python C++ accelerator (the pure-Python protocols are not affected), the PHP library and its thrift_protocol extension, and the Perl, Lua, Smalltalk and OCaml libraries. This issu...
CVE-2026-66859	New	8.7	HIGH				NULL Pointer Dereference, Use of Uninitialized Variable vulnerability in Apache Thrift c_glib bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-82458	New	8.7	HIGH				Memory allocation with excessive size value, Allocation of resources without limits or throttling vulnerability in Apache Thrift Go, netstd, OCaml, Erlang, JavaME, Rust, C++, Java, Kotlin and D language bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-83663	New	8.7	HIGH				Uncontrolled Recursion vulnerability in Apache Thrift go bindings. Both Go transports satisfy a read out of a buffered frame and, when that frame yields no payload bytes, read the next frame and call `Read` again instead of looping. A peer produces such a frame for 4 bytes in `TFramedTransport` (a declared size of zero) or 18 bytes in `THeaderTransport` (a header block th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83745	New	8.7	HIGH				Memory allocation with excessive size value, Improper handling of length parameter inconsistency vulnerability in Apache Thrift nodejs and D lang bindings. Both bindings' WebSocket server transports read the payload length out of the frame header and allocate that many bytes immediately, without checking that the bytes have arrived. A single ~14-byte frame therefore commit...
CVE-2026-85493	New	8.7	HIGH				Uncontrolled Recursion vulnerability in Apache Thrift Dart and Java ME bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-85494	New	8.7	HIGH				Improper handling of length parameter inconsistency, Uncaught exception, Inefficient Algorithmic Complexity, Memory allocation with excessive size value, Initialization of a resource with an insecure default vulnerability in Apache Thrift Python, Ruby, Erlang, Lua, Dart, JavaME, Perl, PHP and D language bindings. This issue affects Apache Thrift: before 0.25.0. Users a...
CVE-2026-86535	New	8.7	HIGH				Loop with unreachable exit condition ('infinite loop'), Improperly controlled modification of object prototype attributes ('prototype pollution') vulnerability in Apache Thrift NodeJS bindings with TJSPProtocol. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-86537	New	8.7	HIGH				Uncaught exception, Loop with unreachable exit condition ('infinite loop'), Integer underflow (wrap or wraparound) vulnerability in Apache Thrift D language bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-87117	New	8.7	HIGH				NULL pointer dereference vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-91137	New	8.7	HIGH				Improper validation of specified quantity in input, Allocation of resources without limits or throttling, Excessive Iteration vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-93925	New	8.7	HIGH				Stack-based buffer overflow, Incorrect bitwise shift of integer vulnerability in Apache Thrift C++ THeaderProtocol. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-93926	New	8.7	HIGH				Missing release of memory after effective lifetime, Missing release of resource after effective lifetime vulnerability in Apache Thrift THeaderTransport. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94422	New	8.7	HIGH				An incorrect implementation of message filtering in xdg-dbus-proxy versions before 0.1.9 allows an attacker to bypass the intended message filtering on the D-Bus session bus by setting a reply serial number on non-reply messages. A malicious or compromised Flatpak app could use this to achieve arbitrary code execution outside its sandbox. xdg-dbus-proxy was designed to be pa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94633	New	8.7	HIGH				Memory allocation with excessive size value, Improper handling of length parameter inconsistency vulnerability in Apache Thrift Dart bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94635	New	8.7	HIGH		0.004		Allocation of resources without limits or throttling, Improper handling of length parameter inconsistency vulnerability in Apache Thrift Lua bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94642	New	8.7	HIGH				Uncaught exception vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94646	New	8.7	HIGH				Uncaught exception, Improper validation of specified quantity in input, Improperly controlled modification of object prototype attributes ('prototype pollution') vulnerability in Apache Thrift nodejs bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94658	New	8.7	HIGH				Inefficient Algorithmic Complexity vulnerability in Apache Thrift Lua bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96277	New	8.7	HIGH				Uncaught exception, Improper Handling of Exceptional Conditions vulnerability in Apache Thrift Ruby bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96294	New	8.7	HIGH				Uncaught exception, Improper Handling of Exceptional Conditions vulnerability in Apache Thrift NodeJS bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-97363	New	8.7	HIGH				The WebSocket Application Programming Interface lacks restrictions on the number of authentication requests. This absence of rate limiting may allow an attacker to conduct denial-of-service attacks or brute-force attacks to gain unauthorized access.
CVE-2026-104414	New	8.6	HIGH				Ghost from 2.5.0 before 6.64.0 contains a stored cross-site scripting vulnerability that allows attackers to inject untrusted scripts into post content via oEmbed photo responses. Attackers can host malicious oEmbed photo responses so that embedding their URL stores scripts that run in the Ghost editor, published site, and newsletter emails, compromising staff admin sessions.
CVE-2026-104418	New	8.6	HIGH				Ghost from 6.10.3 before 6.64.0 contains a remote code execution vulnerability that allows authenticated administrators to run code by abusing theme translation file loading. Attackers with administrator access can upload a crafted theme containing malicious translation files to execute arbitrary code on the Ghost server.
CVE-2026-104457	New	8.6	HIGH				YesWiki before 4.6.7 contains an SQL injection vulnerability in the Bazar filtertags action, which wraps unescaped filterN attribute tokens in quotes and concatenates them into a raw tags.value IN (...) clause. Unauthenticated attackers on default installs can save filtertags markup in a page with a trailing-backslash token that breaks quote parity under MySQL backslash esca...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104471	New	8.6	HIGH				YesWiki before 4.6.7 contains an unrestricted file upload vulnerability that allows authenticated admins to write remote files into the web-accessible files/ directory via Bazar CSV import preview. Attackers can import a CSV whose file or image field references a remote .php URL, which is saved without extension checks and executed as server-side code.
CVE-2026-86326	New	8.6	HIGH				An improper verification of cryptographic signature vulnerability exists in protocol gateways because the device does not properly verify the cryptographic authenticity of firmware images before installation. An attacker with high privileges and access to the firmware update interface could provide a specially crafted or modified firmware image, causing it to be installed on...
CVE-2026-94591	New	8.6	HIGH				Armatura One stores database and message-broker credentials in an install configuration file, encrypting them with AES-128-CBC when this protection is enabled. The encryption key and initialization vector are fixed values embedded in the software itself and are identical across every installation. An attacker with a copy of the installation package can recover this key and i...
CVE-2026-94592	New	8.6	HIGH				Armatura One's database initialization routine assigns a fixed, vendor-defined password to the database superuser account at creation time, rather than generating a unique password per installation. An individual with access to the server operating system and knowledge of this value can authenticate as the database superuser on a deployment where it has not been changed.
CVE-2026-104411	New	8.5	HIGH				Ghost from 6.22.1 before 6.64.0 contains a stored cross-site scripting vulnerability that allows staff users to host scripts by uploading files served with extension-derived content types on the default local storage adapter. Attackers can upload script-bearing files to the site's domain to compromise other staff users' admin sessions.
CVE-2026-104413	New	8.5	HIGH				Ghost from 5.94.0 before 6.64.0 contains a stored cross-site scripting vulnerability that allows staff users, including Contributors, to host arbitrary HTML by abusing bookmark card image fetching. Attackers can create bookmark cards that store non-image files from external websites as icons or thumbnails to compromise other staff users' admin sessions.
CVE-2026-104611	New	8.5	HIGH				A vulnerability was detected in Tenda AC9 15.03.02.13. Affected is an unknown function of the file /goform/fast_setting_internet_set of the component POST Request Handler. Performing a manipulation of the argument netWanType results in stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit is now public and may be used.
CVE-2026-104847	New	8.5	HIGH				ProseMirror's view component renders and manages the editable browser interface for ProseMirror documents. Prior to 1.42.3, prosemirror-view paste handling accepts attacker-provided HTML whose clipboard slice context contains attributes that are not passed through schema attribute validation. When a user pastes the crafted HTML into an editor, the unvalidated context attribu...
CVE-2026-104854	New	8.5	HIGH				Nx is a monorepo solution for TypeScript and polyglot codebases. From 14.6.0 until 22.7.9 and 23.1.2, Nx creates Unix domain sockets for its daemon and isolated plugin workers in shared temporary locations without owner-only directory and socket permissions. Another unprivileged local account on a shared build server, developer host, or multi-user container can discover and ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94593	New	8.5	HIGH				Armatura One's backup and restore routine records the full database connection command, including the superuser password, in plain text in a log file on the host. Credentials disclosed by this finding can be used to access the database when access to the server operating system is available.
CVE-2026-103958	New	8.3	HIGH				Server-side request forgery in the tool server and remote agent connection handling in Loom for AWS before 1.7.0 might allow an authenticated remote user to obtain the credentials of the application's own container role and to read responses from arbitrary internal network locations, via a crafted connection address supplied when registering, updating or testing a tool serve...
CVE-2026-104435	New	8.3	HIGH				Zebra zebra4 4.4.0 and zebra-script 6.0.0 fail to enforce a ZIP-244 consensus rule, accepting V5 transparent inputs signed with SIGHASH_SINGLE that lack a corresponding output. Attackers can broadcast crafted V5 transactions with more inputs than outputs that Zebra accepts but zcashd rejects, causing a network consensus split.
CVE-2026-104458	New	8.3	HIGH				YesWiki before 4.6.7 contains a server-side request forgery vulnerability in validateKeyUrl() that allows unauthenticated attackers to bypass the SSRF guard using 6to4, NAT64, or IPv4-compatible IPv6 addresses. Attackers can send a crafted Signature keyId to the public actor inbox route to reach cloud metadata, loopback services, or internal hosts.
CVE-2026-104463	New	8.3	HIGH				YesWiki before 4.6.7 contains a server-side request forgery vulnerability that allows unauthenticated attackers to trigger server requests by sending signed Follow activities to the public forms actor inbox route. Attackers sign requests with their own keyId while supplying internal actor URLs in the body, reaching internal hosts or cloud metadata via blind GET and POST requ...
CVE-2026-94483	New	8.3	HIGH				Next.js is a React framework for building full-stack web applications. From 16.0.0 until 16.3.8, Image Optimization can follow attacker-controlled DNS resolution for a remote URL that matches images.remotePatterns, allowing the optimized image fetch to reach private IP addresses after the URL passes the allow-list check. Applications without images.remotePatterns are not aff...
CVE-2026-103601	New	8.2	HIGH		0.003		Release of unverified plaintext in the CCM (CcmBlockCipher) and DSTU 7624 CCM (KCcmBlockCipher) AEAD modes in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker to obtain decryptions of ciphertexts of their choosing via forged messages sent to an application that lets the output buffer of a failed decryption be observed, for example through buff...
CVE-2026-103602	New	8.2	HIGH		0.002		Improper certificate validation in PkixNameConstraintValidator in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who controls, or can obtain certificates from, a name-constrained intermediate CA to have certificates accepted during PKIX certification path validation for email addresses, DNS names or URI hosts that lie within excluded subtrees appl...
CVE-2026-103957	New	8.2	HIGH				Server-side request forgery in the OAuth2 discovery handling in Loom for AWS before 1.7.0 might allow an authenticated remote user to obtain the access token of another user of the deployment and to cause the application to issue requests to arbitrary internal network locations, via a crafted discovery document address supplied when registering a tool server or remote agent ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104426	New	8.2	HIGH				Zebra before 6.1.0 contains an inefficient algorithmic complexity vulnerability in remaining_transaction_value that clones the entire block-level spent-UTXO map per transaction during contextual verification. Attackers can mine or seed the mempool with roughly 26,000 minimal single-input transactions in one block, stalling every validating node for over 52 seconds.
CVE-2026-104445	New	8.2	HIGH				YesWiki before 4.6.7 contains an authentication bypass vulnerability in the ActivityPub inbox that fails to bind the verified HTTP signature signer to the activity actor. Unauthenticated attackers with any ActivityPub keypair can send signed Delete or Update activities referencing a mirrored entry's sourceUrl to delete or overwrite other actors' federated entries.
CVE-2026-104450	New	8.2	HIGH				YesWiki before 4.6.7 contains a missing authorization flaw in the pointimage action (tools/attach/actions/pointimage.php), which saves content to an attacker-chosen page with write ACL checks bypassed. Unauthenticated attackers can POST pagetag, title, and description fields to any page rendering {{pointimage}} to append raw HTML or JavaScript to any wiki page, including pag...
CVE-2026-15999	New	8.2	HIGH		0.002		Improper validation of integrity check value in the AES-CCM implementation (CcmParameters and CcmBlockCipher) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an on-path attacker to modify CCM-encrypted content without detection via an AlgorithmIdentifier whose CCMPParameters declare an authentication tag (aes-ICVlen) of zero or another length outside the RFC...
CVE-2026-16001	New	8.2	HIGH		0.002		Exposure of the message authentication key through the encryption keystream in the stream mode of IesEngine (an IesEngine constructed without a block cipher) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker who has observed one encrypted message with known plaintext to forge shorter messages of their choosing that the recipient accepts as a...
CVE-2026-18036	New	8.2	HIGH		0.003		In Bouncy Castle for Java before 1.86, NTRU reduced secret values with the % operator in three helpers whose reference implementations are deliberately division-free, so each reduction was carried out by an integer division whose latency depends on the secret operand. Polynomial.modQ divided by a variable divisor, which a compiler cannot strength-reduce to a multiply the way...
CVE-2026-63567	New	8.2	HIGH		0.005		Observable discrepancy in IesEngine.DecryptBlock in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker who has captured an IES or ECIES ciphertext, and who can submit modified ciphertexts for decryption under the same key pair, to recover its plaintext via a CBC padding-oracle attack, because in block-cipher mode the engine decrypts the cipherte...
CVE-2026-63573	New	8.2	HIGH		0.003		Observable discrepancy in the CMS RSA PKCS#1 v1.5 key-transport unwrap (KeyTransRecipientInformation.UnwrapKey) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker who holds a captured CMS EnvelopedData message, and who can submit many modified messages to an application that decrypts them with the recipient's RSA private key and reveals how d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63576	New	8.2	HIGH		0.002		Improper certificate validation in PkixNameConstraintValidator (ExtractHostFromURL) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a name-constrained subordinate CA, or anyone able to obtain certificates with chosen subjectAltName URIs from such a CA, to bypass permitted or excluded uniformResourceIdentifier name constraints during certification path valid...
CVE-2026-63577	New	8.2	HIGH		0.002		Improper certificate validation in the directoryName name-constraint check (PkixNameConstraintValidator.WithinDNSSubtree) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who controls, or can have certificates issued by, a name-constrained intermediate CA to get certificates accepted by PKIX path validation whose subject distinguished name, or a d...
CVE-2026-66055	New	8.2	HIGH				Allocation of Resources Without Limits or Throttling vulnerability in Apache Thrift C++, Java, Go, netstd, Python and Delphi bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-82459	New	8.2	HIGH				Integer underflow (wrap or wraparound), Out-of-bounds write vulnerability in Apache Thrift C++ 32 bit THeaderTransport. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-85476	New	8.2	HIGH				Loop with unreachable exit condition ('infinite loop') vulnerability in Apache Thrift c_glib bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-90440	New	8.2	HIGH				Uncaught exception, improper handling of exceptional conditions, improper resource shutdown vulnerability in Apache Thrift D thrift.server.nonblocking.TNonblockingServer. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94634	New	8.2	HIGH				Allocation of resources without limits or throttling, Initialization of a resource with an insecure default vulnerability in Apache Thrift Python bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94636	New	8.2	HIGH				Improper handling of highly compressed data (data amplification), Function call with incorrectly specified arguments, Improper validation of specified quantity in input vulnerability in Apache Thrift py bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94637	New	8.2	HIGH				Improper handling of highly compressed data (data amplification) vulnerability in Apache Thrift Go bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94639	New	8.2	HIGH		0.004		improper handling of exceptional conditions, Allocation of resources without limits or throttling, Uncaught exception vulnerability in Apache Thrift Java bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94644	New	8.2	HIGH				Allocation of resources without limits or throttling vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94645	New	8.2	HIGH				Improper validation of specified quantity in input, Allocation of resources without limits or throttling vulnerability in Apache Thrift nodejs bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94648	New	8.2	HIGH				Allocation of resources without limits or throttling vulnerability in Apache Thrift dart bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94650	New	8.2	HIGH				Uncontrolled Recursion vulnerability in Apache Thrift c_glib bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94651	New	8.2	HIGH				improper handling of exceptional conditions, Missing release of resource after effective lifetime vulnerability in Apache Thrift java bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94653	New	8.2	HIGH				Inefficient Algorithmic Complexity vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94654	New	8.2	HIGH				Loop with unreachable exit condition ('infinite loop') vulnerability in Apache Thrift python bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94655	New	8.2	HIGH				Allocation of resources without limits or throttling, Inefficient Algorithmic Complexity vulnerability in Apache Thrift Lua bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94656	New	8.2	HIGH				Allocation of resources without limits or throttling vulnerability in Apache Thrift ruby bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94657	New	8.2	HIGH				Allocation of resources without limits or throttling vulnerability in Apache Thrift JavaME bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96286	New	8.2	HIGH				Uncaught exception vulnerability in Apache Thrift Perl bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96287	New	8.2	HIGH				Inefficient Algorithmic Complexity vulnerability in Apache Thrift Perl bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96288	New	8.2	HIGH				Uncontrolled Recursion, Allocation of resources without limits or throttling vulnerability in Apache Thrift Erlang bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96289	New	8.2	HIGH				Uncontrolled Recursion vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96292	New	8.2	HIGH				Inefficient regular expression complexity, Inefficient Algorithmic Complexity vulnerability in Apache Thrift Lua bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-96990	New	8.2	HIGH				Allocation of Resources Without Limits or Throttling vulnerability in Apache Thrift Erlang bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-101923	New	8.1	HIGH				The Photo Reviews for WooCommerce plugin for WordPress is vulnerable to Arbitrary Content Deletion in versions up to, and including, 1.2.30. This is due to the plugin storing attacker-controlled post IDs from the wcpr_image_upload_id parameter of a public review submission into the review's reviews-images comment meta without verifying that the IDs correspond to attachments ...
CVE-2026-104988	New	8.1	HIGH				A flaw was found in Dogtag PKI (pki-core). The CMCAuthForEST authentication plugin fails open when an EST fullcmc enrollment request is submitted via BasicAuth without an end-user TLS client certificate. The SSL_CLIENT_CERT session attribute retains the EST subsystem's agent certificate, which causes downstream authorization checks to treat the request as agent-privileged. A...
CVE-2026-51907	New	8.1	HIGH				In TaskingAI v0.3.0 in the QR Code Generator plugin save_base64_image function, a path traversal vulnerability allows attackers to write image files to arbitrary locations on the server filesystem by manipulating the project_id parameter.
CVE-2026-104026	New	7.8	HIGH				In Sapling SCM prior to v0.2.20260929-102736, control characters were allowed to be embedded in Git subtree URLs. A maliciously constructed repository, if cloned by a target, could trigger code execution on otherwise read-only actions such as sl log/blame/annotate.
CVE-2026-82044	New	7.7	HIGH				UTMStack before 11.2.16 contains a server-side request forgery vulnerability that allows authenticated attackers to make the server request arbitrary internal resources by supplying an unvalidated url parameter to the PdfService.downloadPdf() method exposed via GET /api/generate-pdf-report. Attackers can leverage this to force the web-pdf microservice to fetch internal backe...
CVE-2026-104873	New	7.6	HIGH				LangGraph Python SDK is used to connect to running LangGraph API servers, manage assistants, threads and stream runs from Python applications. From 0.1.45 until 0.4.4, the langgraph-sdk resource-scoped authorization decorators @auth.on.threads, @auth.on.assistants, and @auth.on.crons ignore the actions argument and register the selected handler for every action on the resour...
CVE-2014-125130	New	7.5	HIGH				CodeArt Google MP3 Audio Player plugin (google-mp3-audio-player) for WordPress through 1.0.11 contains an unauthenticated arbitrary file read vulnerability that allows remote attackers to retrieve sensitive files by supplying a path-traversal payload in the file parameter of direct_download.php. Attackers can request paths ../../wp-config.php without authentication to downlo...
CVE-2026-103913	New	7.5	HIGH				The GeoDirectory plugin for WordPress is vulnerable to SQL Injection via the stored latitude/longitude coordinates of a listing in versions up to, and including, 2.8.186. This is due to insufficient escaping and the absence of numeric validation on coordinate values when a listing is saved, combined with the direct string interpolation of those values into a distance sub-exp...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104416	New	7.5	HIGH				Ghost from 4.39.0 before 6.64.0 contains an information disclosure vulnerability in the Admin API that allows staff users to view secret tokens of pending staff invites. Staff users with invite viewing permission can accept pending invites for higher-privileged roles to escalate their privileges.
CVE-2026-104433	New	7.5	HIGH				Mooncake transfer engine before 0.3.12 contains an out-of-bounds read vulnerability in the readString function of include/common.h that allows unauthenticated attackers to crash the service by sending a zero-length handshake frame. Attackers can connect to the handshake port listening on all interfaces and send an eight-byte frame to terminate the hosting process, such as an...
CVE-2026-104845	New	7.5	HIGH				Seroval facilitates JS value stringification, including complex structures beyond JSON.stringify capabilities. Prior to 1.6.3, deserializeTypedArray in fromJSON and fromCrossJSON trusts a deserialized source value as an ArrayBuffer and does not bound the serialized element count. An attacker can provide a small untrusted JSON object with a large length value, causing the arr...
CVE-2026-104861	New	7.5	HIGH			npm:probe-image-size	probe-image-size gets image dimensions without downloading the entire file. Prior to 7.4.0, lib/parse_sync/svg.js and lib/parse_stream/svg.js use the searching regular expression /<[-_.:a-zA-Z0-9][^>]*>/, which repeatedly scans to the end of input when attacker-controlled data contains many less-than characters without a closing greater-than character. The synchronous parser...
CVE-2026-51916	New	7.5	HIGH				TransformerOptimus SuperAGI v0.0.14 contains an incorrect access control vulnerability in delete_user_knowledge in superagi/controllers/knowledges.py. In affected source snapshots, POST /knowledges/delete/{knowledge_id} deletes the selected knowledge object without requiring authentication in the route and without verifying organization ownership of the supplied knowledge_id.
CVE-2026-67989	New	7.5	HIGH				crmne/ruby_llm at commit fa6f279847d6d7027814539d9c0dfc3bbdfd2a83 contains a polynomial-time regular expression denial-of-service condition in Mistral model capability matching on Ruby 3.1.x
CVE-2026-93428	New	7.5	HIGH				The Ultimate Member – User Profile, Registration, Login, Member Directory, Content Restriction & Membership Plugin plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 2.13.1 This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to view ...
CVE-2026-97337	New	7.5	HIGH				The Simple Membership plugin for WordPress is vulnerable to unauthorized modification of data and sensitive information disclosure in versions up to, and including, 4.8.3 via the resend-activation and email-activation endpoints. The endpoints are dispatched from SwpmlInitTimeTasks::check_and_do_email_activation() on frontend init with no authentication, nonce, capability, or ...
CVE-2026-104437	New	7.4	HIGH				Zebra before 4.4.0 contains a consensus divergence vulnerability in V5 transparent signature verification, computing a ZIP-244 digest for SIGHASH_SINGLE inputs lacking corresponding outputs instead of failing. Attackers can craft V5 transactions with fewer outputs than inputs that Zebra accepts and templates via getblocktemplate, producing blocks zcashd rejects.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104733	New	7.4	HIGH				User Impersonation in ProcessOnes XMMP Server ejabberd <= 26.04 allows an attacker to impersonate arbitrary users via unvalidated authzid parameter in SASL-PLAIN mechanism.
CVE-2026-80443	New	7.4	HIGH		0.002		Improper certificate validation vulnerability in HAVELSAN Inc. Sef - AI Chatbot Platform allows Adversary in the Middle (AiTM). This issue affects Sef - AI Chatbot Platform: before 2.1. NOTE: The vendor was contacted and it was learned that the product is not supported.
CVE-2026-103552	New	7.3	HIGH		0.002		Stack Overflow vulnerability in Apache Directory LDAP API. Before binding, a client can send a deeply nested search filter that overflows the stack in the server's decoder. This issue affects Apache Directory LDAP API: from 1.2.0 before 1.2.9. Users are recommended to upgrade to version 1.2.9, which fixes the issue.
CVE-2026-104609	New	7.3	HIGH				A weakness has been identified in onetwothreeeneth HospitalManagementSystem up to 9ef91ed6007314b6473110ed699dff76d158f61d. This affects the function get of the file edit_accounts.php. This manipulation of the argument user_id/patient_id/physician_id/discounts_id/services_id causes sql injection. Remote exploitation of the attack is possible. The exploit has been made availab...
CVE-2026-104637	New	7.3	HIGH				A weakness has been identified in onetwothreeeneth HospitalManagementSystem up to 9ef91ed6007314b6473110ed699dff76d158f61d. The affected element is the function add_d_patient/add_physician/add_account/update_account/update_subaccount/edit_physician/edit_patient of the file php/controller.php. Executing a manipulation of the argument img can lead to unrestricted upload. The atta...
CVE-2026-104859	New	7.3	HIGH				Nx is a monorepo solution for TypeScript and polyglot codebases. From 21.4.0 until 22.7.8 and from 23.0.0 until 23.1.1, the @nx/docker release pipeline builds docker tag, image lookup, and docker push invocations as shell command strings. The release.docker.repositoryName and registryUrl configuration values are interpolated into those strings and passed to /bin/sh -c, allow...
CVE-2026-100107	New	7.2	HIGH		0.003		The Kubio AI Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'comment' parameter in all versions up to, and including, 2.9.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page.
CVE-2026-100182	New	7.2	HIGH		0.003		The Download Monitor plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Cross-Origin postMessage to Admin Editor in all versions up to, and including, 5.2.10 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an ...
CVE-2026-101928	New	7.2	HIGH				The Magic Tooltips For Contact Form 7 plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'author' parameter in all versions up to, and including, 1.0.34 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102565	New	7.2	HIGH		0.003		The BA Book Everything plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'booking_service_qty' parameter in all versions up to, and including, 1.8.28 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inj...
CVE-2026-102626	New	7.2	HIGH				An authenticated LimeSurvey Community Edition 7.4.0 user with the global Surveys: create permission can store a JavaScript-breaking value in the date_min attribute of a Date/Time question. When another user renders the affected question, LimeSurvey inserts the stored value into a single-quoted inline JavaScript literal without JavaScript-context encoding.
CVE-2026-102772	New	7.2	HIGH		0.003		The CMB2 plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the '<textarea_code field id>' (e.g. kl_code, kl_post_code)' parameter in all versions up to, and including, 2.13.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a ...
CVE-2026-103426	New	7.2	HIGH		0.002		The Relevanssi Premium plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the '_rt' parameter in all versions up to, and including, 2.31.4 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. This...
CVE-2026-104443	New	7.2	HIGH				YesWiki before 4.6.7 contains an empty-filter scope bypass in the triples delete API that allows any authenticated user to delete or forge arbitrary semantic triples regardless of ownership. Attackers can send an empty filter to the triples delete endpoint to remove the admins-group membership triple, emptying the admin group and causing a site-wide authorization lockout.
CVE-2026-104448	New	7.2	HIGH				YesWiki before 4.6.7 contains a cross-site request forgery vulnerability in the ajaxdeletepage handler, which permanently deletes a page on any GET request carrying a jsonp_callback parameter without checking a CSRF token. Attackers can lure a logged-in administrator or page owner to a crafted link to delete arbitrary pages along with their ACLs, links, triples, comments and...
CVE-2026-104456	New	7.2	HIGH				YesWiki before 4.6.7 contains a second-order SQL injection vulnerability in AclService::updateRequestWithACL, where a stored username is concatenated unescaped into a read-ACL LIKE clause. Attackers can self-register an account name containing a double-quote payload, then load non-admin ACL-filtered listings to read database contents and bypass read ACLs.
CVE-2026-87091	New	7.2	HIGH				The Welcart e-Commerce plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Settlement Notification Parameters in all versions up to, and including, 2.12.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inje...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87920	New	7.2	HIGH		0.004		The W3 Total Cache plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Content via Output-Buffer Regex Rewrite in all versions up to, and including, 2.10.6 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesse...
CVE-2026-92977	New	7.2	HIGH				The Real Cookie Banner: GDPR & ePrivacy Cookie Consent plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment in all versions up to, and including, 5.3.5 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an ...
CVE-2026-93430	New	7.2	HIGH				The GD Rating System plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'title' and 'url' Render Args in gdrts_live_handler AJAX in all versions up to, and including, 3.7.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a us...
CVE-2026-93756	New	7.2	HIGH		0.003		The Smash Balloon Social Post Feed – Simple Social Feeds for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Facebook Comment Message via v-html in Admin Builder Preview in all versions up to, and including, 4.13.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitra...
CVE-2026-93875	New	7.2	HIGH				The JetAppointment plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'friendlyTime' parameter in all versions up to, and including, 2.5.2.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page...
CVE-2026-95670	New	7.2	HIGH		0.002		The No External Links plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Log URL via /goto/{base64} Redirect in all versions up to, and including, 5.2.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injec...
CVE-2026-95817	New	7.2	HIGH		0.002		The DoFollow Case by Case plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Content in all versions up to, and including, 3.6.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. Commen...
CVE-2026-96270	New	7.2	HIGH				The Ultimate Member – User Profile, Registration, Login, Member Directory, Content Restriction & Membership Plugin plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'form_id' parameter in all versions up to, and including, 2.13.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96564	New	7.2	HIGH				The SEOPress – AI SEO Plugin & On-site SEO plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Author Display Name in all versions up to, and including, 10.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an i...
CVE-2026-96566	New	7.2	HIGH		0.003		The Newsletter – Send awesome emails from WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'np1' Custom Field Parameter in all versions up to, and including, 9.4.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a...
CVE-2026-96567	New	7.2	HIGH		0.003		The MW WP Form plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'post_id' parameter in all versions up to, and including, 5.1.7 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. The CSRF ...
CVE-2026-96575	New	7.2	HIGH				The Transliterator – Multilingual and Multi-script Text Conversion plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Content via Predictable {rstr_keep} Placeholder in all versions up to, and including, 2.5.8 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scr...
CVE-2026-96578	New	7.2	HIGH		0.003		The GSpeech TTS – WordPress Text To Speech Plugin plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Content in all versions up to, and including, 3.22.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses...
CVE-2026-96650	New	7.2	HIGH				The Strong Testimonials plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'platform_user_photo' Custom Field in all versions up to, and including, 3.3.11 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inj...
CVE-2026-96871	New	7.2	HIGH		0.002		The Mang Board plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'data_type' parameter in all versions up to, and including, 2.4.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. This is...
CVE-2026-97336	New	7.2	HIGH		0.003		The CMB2 plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'file_list' Field Type in all versions up to, and including, 2.13.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. This is only ex...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97341	New	7.2	HIGH				The Visitor Traffic Real Time Statistics plugin for WordPress is vulnerable to Stored DOM-Based Cross-Site Scripting via 'X-Real-IP' HTTP Header in all versions up to, and including, 8.16 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user a...
CVE-2026-97342	New	7.2	HIGH		0.002		The JetFormBuilder — Dynamic Blocks Form Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'choice' Post Meta via Insert/Update Post Action in all versions up to, and including, 3.6.5.4 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will...
CVE-2026-97641	New	7.2	HIGH		0.002		The Relevanssi – A Better Search plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Content in all versions up to, and including, 4.28.3 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page...
CVE-2026-97663	New	7.2	HIGH		0.002		The Customer Reviews for WooCommerce plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Author Name in all versions up to, and including, 5.122.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inje...
CVE-2026-104434	New	7.1	HIGH				ZcashFoundation Zebra zebra-rpc before 8.0.0 and zebrad before 4.5.0 contain a reachable assertion in the z_listunifiedreceivers RPC handler, which calls expect() on Sapling receiver parsing that fails for Unified Addresses carrying invalid Jubjub points. Authenticated RPC clients can submit such an address to abort the zebrad process, repeatably keeping the node offline.
CVE-2026-104439	New	7.1	HIGH				YesWiki before 4.6.7 contains a user enumeration vulnerability in LostPasswordAction.php that allows unauthenticated attackers to confirm registered email addresses through differing responses. Attackers can submit emails to the MotDePassePerdu recovery page without rate limiting to identify valid accounts for targeted phishing or password-spraying.
CVE-2026-104444	New	7.1	HIGH				YesWiki before 4.6.7 contains an authorization bypass vulnerability in the comments API editComment route that allows authenticated low-privilege users to overwrite arbitrary pages or comments by supplying their own page as the pagetag field. Attackers can send a POST request to the api/comments endpoint targeting a victim tag, bypassing per-page write ACLs to replace conten...
CVE-2026-104447	New	7.1	HIGH				YesWiki before 4.6.7 contains a cross-site request forgery vulnerability in the autoupdate UpdateAction that allows attackers to delete installed packages via unprotected GET requests. Attackers can lure a logged-in administrator to a crafted link with action=delete and a package parameter to remove extensions like bazar, breaking core site functionality.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104478	New	7.1	HIGH				Formwork before 2.3.13 contains a path traversal vulnerability in BackupController that allows authenticated panel users to read or delete arbitrary files. Attackers with backup download or delete permission can supply a base64-encoded backslash-separated traversal payload that bypasses PHP basename on Linux to access files outside the backup directory.
CVE-2026-104908	New	7.1	HIGH				MISP contains an improper input validation vulnerability in the decaying model import functionality. The import endpoint was intended to create a new decaying model belonging exclusively to the importing user's organisation, with the default flag forced to off. However, the application stripped only the top-level id and uuid fields and pinned org_id and default on the outer...
CVE-2026-104912	New	7.1	HIGH				MISP contains an authorization flaw in its correlation handling during attribute searches. When a user performs an attribute search that triggers correlation lookups, the system authorized access to correlated attributes and events based on a stale distribution snapshot stored on the correlation row rather than the live event access control list. Because the correlation row...
CVE-2026-104991	New	7.1	HIGH				Phproject before 1.8.7 contains a missing object-level authorization vulnerability in the REST API issue endpoints (single_get, single_comments, single_comments_post) that allows authenticated API key holders to bypass the security.restrict_access confidentiality control by never invoking the allowAccess() authorization routine. Attackers can use a valid API key to read rest...
CVE-2026-105050	New	7.1	HIGH				PeaZip before 11.3.0, in a non-default configuration, is vulnerable to OS command injection via a filename in an archive because "quotation character already used in the string" is mishandled.
CVE-2026-61374	New	7.1	HIGH				Allocation of Resources Without Limits or Throttling vulnerability in Apache Thrift Java bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-63570	New	7.1	HIGH		0.002		Loop with unreachable exit condition in Pkcs12Store.GetCertificateChain in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who can supply a crafted PKCS#12 file to an application that loads it and requests a key entry's certificate chain to cause a denial of service, in which the call never returns and consumes CPU and memory until an OutOfMemoryEx...
CVE-2026-63572	New	7.1	HIGH		0.003		Allocation of resources without limits in PKCS#12 keystore loading (Pkcs12Store.Load) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who can supply a PKCS#12 (PFX) file to cause a denial of service through CPU exhaustion via an iteration count close to 2^31 in the file's MacData or in the PBE parameters of an encrypted SafeContents or shrouded ...
CVE-2026-63575	New	7.1	HIGH		0.002		Loop with unreachable exit condition in the PKCS#12 key derivation (Pkcs12ParametersGenerator) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who can supply a PKCS#12 (PFX) file, or a PKCS#8 encrypted private key that uses a PKCS#12 password-based encryption algorithm, to cause a denial of service through CPU exhaustion via an iteration count o...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63578	New	7.1	HIGH		0.003		Allocation of resources without limits in password-based private-key decryption (PbeUtilities.GenerateCipherParameters) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who can supply an encrypted private key, such as a PKCS#8 EncryptedPrivateKeyInfo or "ENCRYPTED PRIVATE KEY" PEM file, to cause a denial of service through CPU exhaustion via an i...
CVE-2026-85215	New	7.1	HIGH				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in GG Soft Software Services Inc. Paperwork allows SQL Injection. This issue affects Paperwork: through 2026-09-09.
CVE-2026-96613	New	7.1	HIGH				The Meari IoT Cloud Platform OpenAPI Service is vulnerable to an authorization flaw that allows authenticated users to access the complete device shadow of any device by specifying its device ID. This vulnerability exposes sensitive information, such as device credentials, owner details, network data, and telemetry, without verifying any relationship between the requester an...
CVE-2026-102795	New	7.0	HIGH				Improper Access Control vulnerability in Apache Traffic Server. This issue affects Apache Traffic Server: from 9.0.0 through 9.2.14, from 10.0.0 through 10.1.3. Users are recommended to upgrade to version 9.2.15 or 10.1.4, which fixes the issue. This CVE supersedes CVE-2026-41920, whose record listed the affected 9.x versions as 9.0.0 through 9.1.14 and the fixed ve...
CVE-2026-103763	New	6.9	MEDI				SiYuan before v3.8.5 contains an information disclosure vulnerability that allows read-only publish readers to learn metadata of publish-excluded documents through the getNotebookInfo endpoint. Attackers, including anonymous visitors when no reader password is set, can query publish-visible notebooks to obtain document count, size and modification timestamps of hidden docume...
CVE-2026-104417	New	6.9	MEDI				Ghost from 1.20.0 before 6.64.0 contains a path traversal vulnerability in theme translation file loading that allows authenticated administrators to read JSON files outside the active theme directory. Attackers can manipulate the locale setting to load JSON files elsewhere on the server, exposing server configuration secrets.
CVE-2026-104421	New	6.9	MEDI				Zebra before 6.2.1 contains an incomplete cleanup vulnerability that allows unauthenticated peers to block downloading of valid blocks by leaving rejected hashes in SentHashes. Attackers can send a contextually invalid block sharing an honest block's header hash, causing Request::KnownBlock to skip the honest block and keep nodes behind the tip.
CVE-2026-104425	New	6.9	MEDI				ZcashFoundation Zebra before 6.1.0 contains a resource exhaustion vulnerability that allows unauthenticated peers to degrade block processing by pushing transactions with invalid Orchard proofs without being misbehavior-scored. Attackers can repeatedly push invalid proofs into the shared halo2 batch verifier, forcing honest block proofs onto the slow individual-verification ...
CVE-2026-104429	New	6.9	MEDI				Zebra (zebrad) 5.0.0 before 6.0.0-rc.0 does not apply its per-peer mempool admission cap to transactions received as direct P2P tx messages, because these are queued without the sending peer recorded as their source. A remote inbound peer can push many unique transactions to occupy a disproportionate share of mempool admission slots, crowding out honest peers' transaction re...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104440	New	6.9	MEDI				YesWiki before 4.6.7 contains a blind server-side request forgery vulnerability that allows unauthenticated attackers to make arbitrary server-side requests via the idtypeannonce parameter of /api/entries/bazalist. Because isValidURL() always returns true, attackers can supply internal URLs fetched by curl in loadURLContent() to probe internal networks and reach internal se...
CVE-2026-104442	New	6.9	MEDI				YesWiki before 4.6.7 contains an unauthenticated server-side request forgery vulnerability that allows remote attackers to make the server fetch arbitrary URLs by supplying a syndication action through the render handler's content parameter. Attackers can target internal hosts and ports, read back fetched feed content in the rendered page, and cause feed enclosures to be dow...
CVE-2026-104446	New	6.9	MEDI				YesWiki before 4.6.7 contains an authentication bypass in the contact mail AJAX handler that allows unauthenticated attackers to send email through the wiki's SMTP server. Attackers can POST an XMLHttpRequest to the mail handler without field or type parameters, supplying arbitrary recipient, sender, subject and body for spam and phishing.
CVE-2026-104454	New	6.9	MEDI				YesWiki before 4.6.7 contains an algorithmic-complexity denial of service in the wakka.php formatter due to an O(n^2) markdown-link regex. Unauthenticated attackers can submit a small crafted body of bracket characters to the page-edit preview endpoint to pin PHP-FPM workers and saturate the pool.
CVE-2026-104455	New	6.9	MEDI				YesWiki before 4.6.7 contains an access control bypass vulnerability that allows unauthenticated attackers to read restricted page content via the recentchangesrssplus RSS action. Attackers can request the xml method of a page hosting the action to retrieve 500-character body excerpts of every latest page, including read-restricted drafts and notes.
CVE-2026-104459	New	6.9	MEDI				YesWiki before 4.6.7 contains a server-side request forgery vulnerability in WebfingerService that allows unauthenticated attackers to trigger HTTPS requests to internal hosts. Attackers can POST a crafted actor_handle with a numeric host and port to the abonnements view to probe internal HTTPS services and ports.
CVE-2026-66054	New	6.9	MEDI				Allocation of Resources Without Limits or Throttling, Improper Handling of Highly Compressed Data (Data Amplification) vulnerability in Apache Thrift C++ bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-66331	New	6.9	MEDI				Allocation of Resources Without Limits or Throttling vulnerability in Apache Thrift Delphi bindings buffered transport. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-85086	New	6.9	MEDI				Improper certificate validation, Initialization of a resource with an insecure default vulnerability in Apache Thrift perl bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-85087	New	6.9	MEDI				Improper certificate validation, Return of wrong status code vulnerability in Apache Thrift python bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85088	New	6.9	MEDI				Improper Validation of Certificate with Host Mismatch in the C++ and D libraries of Apache Thrift. Both libraries install a default access manager for client sockets — TSSLConnectionFactory does so in C++, and the accessManager property does so in D — which compares the peer certificate against the host name that was connected to. That comparison walks the subjectAltName dNS...
CVE-2026-93474	New	6.9	MEDI				Charging station authentication identifiers are publicly accessible via web-based mapping platforms.
CVE-2026-97212	New	6.9	MEDI				The WebSocket backend uses charging station identifiers to uniquely associate sessions but allows multiple endpoints to connect using the same session identifier. This implementation results in predictable session identifiers. This vulnerability may allow unauthorized users to authenticate as other users or enable a malicious actor to cause a denial-of-service condition by o...
CVE-2026-104469	New	6.8	MEDI				YesWiki before 4.6.7 contains a session fixation vulnerability that allows attackers to hijack authenticated sessions because login does not regenerate the PHP session ID. Attackers who set or learn a victim's pre-authentication YesWiki-* session cookie can reuse it after login to access private content and perform actions with the victim's privileges.
CVE-2026-104474	New	6.7	MEDI				OpenLiteSpeed before 1.9.3 contains a local privilege escalation vulnerability in admin/misc/sup.sh that runs unverified update packages from a nobody-writable directory as root. Attackers controlling the nobody web process can replace the package in /usr/local/lsws/autoupdate/ before extraction, so its install.sh runs as root on the next update.
CVE-2026-100152	New	6.5	MEDI				The The All in One SEO – AI SEO Plugin to Boost SEO Rankings & Traffic (Schema, Local SEO, Sitemap & SEO Insights) plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 5.0.2 This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it pos...
CVE-2026-102798	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in ThemeREX Group ThemeREX Addons trx_addons allows Stored XSS.This issue affects ThemeREX Addons: from n/a through 2.46.0.
CVE-2026-103036	New	6.5	MEDI				oRPC is a tool that helps build APIs that are end-to-end type-safe and adhere to OpenAPI standards. Prior to 1.14.9, the @orpc/json-schema SmartCoercionPlugin uses JsonSchemaCoercer to collect object properties in a plain object and to resolve schema.properties entries through the prototype chain. A remote client that can reach a procedure with an object input schema can sup...
CVE-2026-103918	New	6.5	MEDI				oRPC is a tool that helps build APIs that are end-to-end type-safe and adhere to OpenAPI standards. Prior to 1.14.10, the @orpc/zod ZodSmartCoercionPlugin and experimental_ZodSmartCoercionPlugin collect object and record properties in plain objects and resolve shape keys through the prototype chain. A remote client that can reach a procedure with an object or record input ca...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104449	New	6.5	MEDI				YesWiki before 4.6.7 contains an access control vulnerability allowing unauthenticated attackers to overwrite any existing wiki page, including pages whose write ACL restricts editing, via the Bazar entry-creation flow. Attackers can submit a crafted entry with an attacker-controlled id_fiche matching an existing page, overwriting its body for mass defacement and content des...
CVE-2026-12951	New	6.5	MEDI		0.003		The Dc Woocommerce Multi Vendor plugin for WordPress is vulnerable to SQL Injection via the 'order_by' parameter of the /multivendorx/v1/compliance/report-abuse REST endpoint in versions up to and including 5.0.18. This is due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query — the value is concatenated direc...
CVE-2026-19856	New	6.5	MEDI				The All in One SEO WordPress plugin before 5.0.2.1 does not correctly determine which shortcodes are present in content derived from user input before deciding which ones to strip, allowing unauthenticated users to execute arbitrary shortcodes registered on the site. On sites upgraded from older versions the protection is disabled outright, making the issue reachable without...
CVE-2026-32585	New	6.5	MEDI				Missing Authorization vulnerability in airano Airano MCP Bridge airano-mcp-bridge allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects Airano MCP Bridge: from n/a through 2.11.0.
CVE-2026-39439	New	6.5	MEDI				Missing Authorization vulnerability in Kiera Howe WebSamurai websamurai allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects WebSamurai: from n/a through 1.0.7.
CVE-2026-82045	New	6.5	MEDI				UTMStack before 11.2.16 contains a JPQL injection vulnerability that allows authenticated attackers to read arbitrary entity data by exploiting UtmNetworkScanService.searchPropertyValues(), which builds a JPQL query with String.format() and executes it via em.createQuery() without parameter binding. Attackers can inject malicious JPQL through the value parameter in the GET /...
CVE-2026-84740	New	6.5	MEDI		0.002		The Events Calendar WordPress plugin before 6.17.5.1 does not validate or sanitise data submitted to an unauthenticated AJAX action before merging it into its rendering context, allowing unauthenticated users to execute arbitrary shortcodes registered on the site.
CVE-2026-85209	New	6.5	MEDI				Missing Authorization vulnerability in AVEZ Electronics Communication Training and Consultancy Trade Inc. Learning Management System (LMS) allows Exploiting Incorrectly Configured Access Control Security Levels. This issue affects Learning Management System (LMS): through 2026-09-18.
CVE-2026-94539	New	6.5	MEDI				The SupportCandy – AI Customer Support Ticket System & Live Chatbot Agent plugin for WordPress is vulnerable to time-based SQL Injection via the 'sort_by' parameter in all versions up to, and including, 3.5.3 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attac...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95865	New	6.5	MEDI				The Beaver Builder Page Builder – Drag and Drop Website Builder plugin for WordPress is vulnerable to blind SQL Injection via 'fields[][value]' Parameter in all versions up to, and including, 2.11.0.5 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attackers, wi...
CVE-2026-97634	New	6.5	MEDI		0.003		The Event Tickets and Registration plugin for WordPress is vulnerable to generic SQL Injection via the 'orderby' parameter in all versions up to, and including, 5.29.5 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attackers, with contributor-level access and a...
CVE-2025-12828	New	6.4	MEDI				The Ultra Addons Lite for Elementor plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Type Out widget in all versions up to, and including, 1.3.2 due to insufficient input sanitization and output escaping on user supplied attributes. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web sc...
CVE-2026-100148	New	6.4	MEDI				The Rich Showcase for Google Reviews plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'reviews[].text' parameter in all versions up to, and including, 7.1.3 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitrary web scripts in pages th...
CVE-2026-102797	New	6.4	MEDI				Server-Side Request Forgery (SSRF) vulnerability in ThemeREX Group ThemeREX Addons trx_addons allows Server Side Request Forgery.This issue affects ThemeREX Addons: from n/a through 2.46.0.
CVE-2026-92727	New	6.4	MEDI				The EmbedPress – PDF Embedder, 3D PDF FlipBook, Google Reviews, YouTube Videos, Upload & Embed PDF documents plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'slidesShow' Block Attribute in all versions up to, and including, 4.6.6 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contribu...
CVE-2026-94378	New	6.4	MEDI				The SupportCandy – AI Customer Support Ticket System & Live Chatbot Agent plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'name' parameter in all versions up to, and including, 3.5.3 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitr...
CVE-2026-96647	New	6.4	MEDI		0.002		The Listdom: AI-powered Business Directory with Classifieds Ads Listings plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'lsd[remark]' Parameter in all versions up to, and including, 6.1.1 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arb...
CVE-2026-97338	New	6.4	MEDI		0.002		The Download Manager plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Display Name in all versions up to, and including, 3.3.70 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitrary web scripts in pages that will execute whenever a user a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97344	New	6.4	MEDI				The Wp Social Login and Register Social Counter plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Avatar Alt Attribute via Arbitrary User Meta Write in all versions up to, and including, 3.2.1 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject ar...
CVE-2026-97876	New	6.4	MEDI				A local attacker with control over GRUB's configuration can bypass lockdown restrictions when booting with Secure Boot and load an unsigned GRUB module, while GRUB continues to report lockdown is enabled. The vulnerability is caused by insufficient validation of the MMIO base address passed to the GRUB serial command. GRUB does not validate that the base address correspo...
CVE-2026-101104	New	6.3	MEDI				The Meari IoT Cloud Platform OpenAPI Service is vulnerable to an authorization flaw that allows authenticated users to manipulate the configurations of devices they do not own. This vulnerability enables attackers to perform unauthorized actions, such as altering device settings or triggering unintended behaviors, without verifying ownership or permissions.
CVE-2026-104436	New	6.3	MEDI				Zebra before 4.5.0 contains an uncontrolled resource consumption vulnerability that allows remote P2P peers to exhaust blocking-pool threads by sending oversized block locator vectors. Attackers can send getblocks or getheaders messages with up to 65,535 locator hashes, triggering per-hash chain lookups that degrade block validation, RPC, and mempool performance.
CVE-2026-104468	New	6.3	MEDI				YesWiki before 4.6.7 contains an insufficient session expiration vulnerability that allows attackers to reuse old password reset links because tokens lack expiry timestamps. Attackers who obtain an unused reset URL from mailboxes, logs, backups, or browser history can submit a new password through checkEmailKey() and take over accounts.
CVE-2026-104625	New	6.3	MEDI				A security flaw has been discovered in CodeAstro Simple Loan Management System 1.0. Impacted is an unknown function of the file /admin/index.php. Performing a manipulation of the argument g_name results in sql injection. The attack may be initiated remotely. The exploit has been released to the public and may be used for attacks.
CVE-2026-104721	New	6.3	MEDI				Path-traversal vulnerability in QOS.CH Sarl Logback-classic on Java (logback-classic module) allows path-traversal vulnerability. More specifically, an MDC-based discriminator value flows unsanitized into a nested FileAppender path, letting an attacker who influences that MDC value (e.g. via an HTTP header) create and append log files outside the intended directory. T...
CVE-2026-104871	New	6.3	MEDI				The Angular SSR is a server-rise rendering tool for Angular applications. Prior to versions 20.3.36, 21.2.23, and 22.1.7, the CommonEngine retrieveSSGPage prerendered-page retrieval logic in @angular/ssr/node, and in @angular/ssr for versions 17 through 18, accepts a relative request URL containing a backslash parent-traversal segment on Windows. The non-special resolve:// U...
CVE-2026-85483	New	6.3	MEDI				Use of uninitialized resource, Return of wrong status code vulnerability in Apache Thrift c_glib bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86536	New	6.3	MEDI				Improperly controlled modification of object prototype attributes ('prototype pollution') vulnerability in Apache Thrift all JS bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0 and re-generate JS code, which fixes the issue.
CVE-2026-92834	New	6.3	MEDI				Use of uninitialized resource, Return of wrong status code vulnerability in Apache Thrift C++ WebSocket server. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94484	New	6.3	MEDI				Next.js is a React framework for building full-stack web applications. From 15.0.0 until 15.5.27 and 16.3.8, applications with a root-level catch-all page and statically generated or Incremental Static Regeneration routes can use a shared response cache key that is insufficiently scoped to the source route. A single unauthenticated crafted request can poison that cache, caus...
CVE-2026-94485	New	6.3	MEDI				Next.js is a React framework for building full-stack web applications. From 16.0.0 until 16.3.8, the `next dev` development server exposes a Model Context Protocol endpoint without reliably restricting cross-site requests. A malicious website visited by a developer can reach the endpoint and read the project's disk location, source code snippets from error reports, route inv...
CVE-2026-94543	New	6.3	MEDI				Next.js is a React framework for building full-stack web applications. From 15.0.0 until 15.5.27 and 16.3.8, self-hosted applications using the Pages Router with statically generated or Incremental Static Regeneration pages can key a response cache entry without sufficiently binding it to the source route. A request can replace one page's cache entry with content from a diff...
CVE-2026-94544	New	6.3	MEDI				Next.js is a React framework for building full-stack web applications. From 16.3.0 until 16.3.8, pending use cache fills for the same key are shared without separating Draft Mode requests from regular requests. An overlapping regular request can receive unauthenticated unpublished content from an editor's Draft Mode fill, while an overlapping Draft Mode request can receive p...
CVE-2026-94638	New	6.3	MEDI				Allocation of resources without limits or throttling vulnerability in Apache Thrift PHP bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-94652	New	6.3	MEDI				Missing release of memory after effective lifetime vulnerability in Apache Thrift c++ bindings. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-104906	New	6.2	MEDI				MISP contains a cross-site scripting (XSS) vulnerability in the TAXII object viewer. When displaying a remote TAXII object, the JSON content of string properties was rendered directly into an HTML pre block without HTML-encoding. An attacker who can control or influence the content of a TAXII object (e.g., by publishing a malicious object to a TAXII server that the victim's ...
CVE-2026-103888	New	6.1	MEDI				The WPC Smart Quick View for WooCommerce plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'woosq-redirect' parameter in all versions up to, and including, 4.4.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they can successfu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103909	New	6.1	MEDI				The Calculated Fields Form – AI Form Builder for WordPress – Contact, Payment, Quote, Quiz & More plugin for WordPress is vulnerable to Reflected DOM-Based Cross-Site Scripting via the 'arbitrary (whichever names the admin bound via url.<name>)' parameter in all versions up to, and including, 5.5.1.5 due to insufficient input sanitization and output escaping. This makes it p...
CVE-2026-104465	New	6.1	MEDI				YesWiki before 4.6.7 contains a reflected cross-site scripting vulnerability that allows unauthenticated attackers to inject scripts via the field parameter of the mail handler. Attackers can craft links whose field value breaks out of the ajax-mail-form action attribute to execute JavaScript in victims' browsers.
CVE-2026-104473	New	6.1	MEDI				YesWiki before 4.5.3 contains multiple reflected cross-site scripting vulnerabilities that allow remote attackers to inject JavaScript through unsanitized parameters such as incomingurl, id, file, tags, and template. Attackers can lure authenticated or unauthenticated users into opening crafted links to hijack sessions and trigger authenticated requests against backend funct...
CVE-2026-104477	New	6.1	MEDI				Showdown through 2.1.0 contains a cross-site scripting vulnerability in the makehtml link and image subparsers, which fail to escape double quotes in destination URLs placed into href and src attributes. Attackers can craft markdown links or images containing a double quote followed by onerror or onmouseover handlers to execute script when victims view rendered HTML.
CVE-2026-85492	New	6.1	MEDI		0.004		The All in One SEO – AI SEO Plugin to Boost SEO Rankings & Traffic (Schema, Local SEO, Sitemap & SEO Insights) plugin for WordPress is vulnerable to DOM-Based Cross-Site Scripting via URL Pathname in all versions up to, and including, 5.0.1.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary w...
CVE-2026-92243	New	6.1	MEDI				The Ivory Search – WordPress Search Plugin plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 's' parameter in all versions up to, and including, 5.5.18 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses a...
CVE-2026-92538	New	6.1	MEDI				The LearnPress – WordPress LMS Plugin for Create and Sell Online Courses plugin for WordPress is vulnerable to Reflected DOM-Based Cross-Site Scripting via the 'orderby' parameter in all versions up to, and including, 4.4.7 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages...
CVE-2026-92551	New	6.1	MEDI				The Paid Membership Plugin, Ecommerce, User Registration Form, Login Form, User Profile & Restrict Content – ProfilePress plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via ppress_billing_address Filename Parameter in all versions up to, and including, 4.17.4 due to insufficient input sanitization and output escaping. This makes it possible for unauthen...
CVE-2026-92826	New	6.1	MEDI				The EWWW Image Optimizer plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via REQUEST_URI Parameter Key in all versions up to, and including, 8.7.7 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they can successfully trick a user into...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93880	New	6.1	MEDI		0.002		The Greenshift – animation and page builder blocks plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via '{{GET:}}' Dynamic Placeholder in all versions up to, and including, 13.2.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they ca...
CVE-2026-97652	New	6.1	MEDI		0.005		The WP Statistics – Simple, privacy-friendly Google Analytics alternative plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via REQUEST_URI Query-Parameter Key in all versions up to, and including, 14.16.14 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pag...
CVE-2026-104427	New	5.9	MEDI				Zebra before 6.1.0 contains an incomplete cleanup vulnerability in the state write task that allows remote unauthenticated peers to stall node synchronization by poisoning parent_error_map. Attackers can deliver a coinbase-malleated block sharing a canonical block's hash before it propagates, causing the next canonical block to be rejected and stalling the node for roughly 2...
CVE-2026-104476	New	5.9	MEDI				Backdrop CMS before 1.35.1 contains an information disclosure vulnerability that allows unauthenticated attackers to retrieve configuration export archives left on the server after transfer. Attackers can download compressed archives generated by users with configuration export permission to obtain the full site configuration, including sensitive settings.
CVE-2026-104843	New	5.9	MEDI				uv is a Python package and project manager written in Rust. From 0.12.7 until 0.12.18, uv wheel extraction on Windows can process a malicious wheel in a way that writes a file outside the installation prefix, including an executable in a directory already present on the user's PATH. Non-Windows hosts are not affected. This issue is fixed in version 0.12.18.
CVE-2026-104844	New	5.9	MEDI				PostCSS Selector Parser is a CSS selector parser that integrates with PostCSS but does not require it. Prior to 7.1.6, src/parser.js splitWord() can receive a flat selector as one word token carrying many class or ID indexes because period and hash characters are not tokenizer word delimiters. The uniqs() deduplication and per-index class and ID membership checks repeatedly ...
CVE-2026-104853	New	5.8	MEDI				Nx is a monorepo solution for TypeScript and polyglot codebases. From 13.10.0 until 22.7.10 and 23.2.1, Nx migration planning reads the nx-migrations.migrations value from a target package manifest without validating that it is a contained relative path. A hostile direct dependency or a package introduced through a trusted package's packageGroup can supply .. segments or an ...
CVE-2026-104872	New	5.8	MEDI				OpenTelemetry JavaScript Contrib provides instrumentation libraries for collecting telemetry from JavaScript applications. Prior to versions 0.66.0 of @opentelemetry/instrumentation-cassandra-driver, 0.65.0 of @opentelemetry/instrumentation-knex, 0.67.0 of @opentelemetry/instrumentation-mongoose, @opentelemetry/instrumentation-mysql, and @opentelemetry/instrumentation-mysql2...
CVE-2026-105049	New	5.8	MEDI				Zilliz Attu before 3.0.0 has a Playground feature that does not require authentication for proxying arbitrary HTTP and HTTPS requests to URLs on the public internet.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104638	New	5.5	MEDI				A security vulnerability has been detected in onetwothreeenth HospitalManagementSystem up to 9ef91ed6007314b6473110ed699dff76d158f61d. The impacted element is an unknown function of the file php/sessions.php. The manipulation of the argument ID leads to improper authentication. Remote exploitation of the attack is possible. The exploit has been disclosed publicly and may be ...
CVE-2026-95512	New	5.5	MEDI		0.002		A flaw was found in FreeType, specifically within its CID font loader. A remote attacker could exploit this vulnerability by tricking a user into opening content that embeds or references a specially crafted CID-keyed font. This crafted font can cause repeated allocations and decryptions of subroutine data across multiple font dictionaries, leading to excessive memory and CP...
CVE-2026-100180	New	5.4	MEDI				The Jeg Kit for Elementor – Powerful Addons for Elementor, Widgets & Templates for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment in all versions up to, and including, 3.2.19 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that wi...
CVE-2026-104453	New	5.4	MEDI				YesWiki before 4.6.7 contains a cross-site request forgery vulnerability in the admintag action that allows attackers to delete tag associations by luring administrators to crafted GET links. Attackers can supply a wide id range in the delete_tag parameter via top-level navigation, carrying the SameSite=Lax admin cookie, to bulk-delete tag triples.
CVE-2026-104461	New	5.4	MEDI				YesWiki before 4.6.7 contains a stored cross-site scripting vulnerability in the Bazar FileField, which validates only the upload's file extension and never calls HtmlPurifierService::cleanFile, so SVG files are stored verbatim and served inline as image/svg+xml. Authenticated users can submit entries via POST /api/entries/{formId} with SVG files containing script that execu...
CVE-2026-104475	New	5.4	MEDI				IDURAR ERP CRM through 4.1.1 contains a stored cross-site scripting vulnerability that allows authenticated users to inject scripts by uploading unsanitized SVG files. Attackers can upload JavaScript-laden SVGs via the profile update or settings upload endpoints, which execute in victims' browsers when served from the /public route.
CVE-2026-104479	New	5.4	MEDI				Shopclass before 6.2.0 contains a stored cross-site scripting vulnerability that allows self-registered non-admin users to inject scripts into item listing descriptions when frontend TinyMCE is enabled. Attackers can submit malicious JavaScript, which ItemActions.php saves without tag stripping, causing it to execute in the site origin for any visitor viewing the listing.
CVE-2026-39444	New	5.4	MEDI				Authorization Bypass Through User-Controlled Key vulnerability in PublishPress PublishPress Series organize-series allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects PublishPress Series: from n/a through 3.1.3.
CVE-2026-85005	New	5.4	MEDI		0.002		The Popup Maker WP WordPress plugin through 1.4.5 does not perform authorization checks on several of its actions and exposes its management page to any logged-in user, allowing users with a low-privileged role such as Subscriber to store display-targeting values that are later invoked as zero-argument PHP callables on public page loads, leading to sensitive information disc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92924	New	5.4	MEDI		0.002		The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not check that a request to render widget output comes from a user allowed to make it, allowing users with a role as low as subscriber to have arbitrary WordPress shortcodes executed on the site. Version 2.0.18 removed the subscriber-level access, so from 2.0.18 onward the issue requires a Contributor r...
CVE-2026-100149	New	5.3	MEDI				The WPZOOM Connect: AI Chat, Click to Chat, Social Icons & Share Buttons plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 4.7.3 via the 'x-yamidoo-signature (attacker-obtained via inline_js identify payload)' parameter. This makes it possible for unauthenticated attackers to extract the full customer card — including ...
CVE-2026-103762	New	5.3	MEDI				SiYuan before v3.8.5 contains a missing authorization vulnerability in the getRefCreateSavePath, getShorthandSavePath, and getDocCreateSavePath endpoints that allows read-only publish visitors to learn unpublished notebook box IDs. Attackers with read-only or anonymous publish access can POST any open notebook ID to receive the global save-box ID and save-path template, reve...
CVE-2026-104055	New	5.3	MEDI				The postgresql-operator charm runs a Prometheus postgres_exporter to collect database metrics using a dedicated "monitoring" PostgreSQL user. On database connection errors, the exporter writes the monitoring user's password in cleartext to its logs. Any actor able to read those logs can recover the password, which grants read-only pg_monitor access to PostgreSQL. This is fix...
CVE-2026-104403	New	5.3	MEDI		0.003		Authorization Bypass Through User-Controlled Key vulnerability in ThimPress LearnPress allows Exploiting Incorrectly Configured Access Control Security Levels. This issue affects LearnPress: from n/a through 4.4.9.
CVE-2026-104420	New	5.3	MEDI				Zebra before 6.3.0 contains a protection mechanism failure that allows unauthenticated peers to evade misbehavior scoring by supplying invalid gossiped blocks. The inbound cleanup step wrongly downcasts RouterError to VerifyBlockError and discards the score, so attackers can repeatedly force block download and Equihash verification without being banned.
CVE-2026-104428	New	5.3	MEDI				The getblock RPC method in zebra-rpc before 11.0.0, used by the Zcash Foundation's Zebra node, panics on verbosity 2 for a side-chain block because the block's -1 confirmations sentinel is converted to u32 with .expect(), aborting the process. Remote unauthenticated attackers, directly or through lightwalletd, can repeat this call to keep the node in a crash loop.
CVE-2026-104432	New	5.3	MEDI				Zebra before 6.3.0 contains an improper exceptional condition check in ChainSync::obtain_tips that discards valid one-hash FindBlocks responses, falsely reporting close-to-tip status. Peers returning only the next block hash cause a zero-length sync sample, making the /ready endpoint return 200 OK while the node remains behind the tip.
CVE-2026-104441	New	5.3	MEDI				YesWiki before 4.6.7 contains an unauthenticated server-side request forgery vulnerability that allows remote attackers to make the server fetch arbitrary hosts and ports via the {{valeur}} action's url parameter. Attackers can submit the action through the content parameter of handlers/page/render.php to probe internal HTTP services and read back response content matching f...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104451	New	5.3	MEDI				YesWiki before 4.6.7 contains a cross-site request forgery vulnerability in RevisionsHandler that allows attackers to restore old page revisions through GET requests lacking CSRF token validation. Attackers can lure write-capable users into a top-level navigation with the restoreRevisionId parameter, silently overwriting current page content with stale or vandalized revisions.
CVE-2026-104452	New	5.3	MEDI				YesWiki before 4.6.7 contains a cross-site request forgery vulnerability in the filemanager page handler, which deletes page attachments on GET requests without validating a CSRF token. Attackers can lure a logged-in page owner or administrator into a top-level GET navigation with do=del, erase, or emptytrash, deleting or permanently purging the page's attachments.
CVE-2026-104470	New	5.3	MEDI				YesWiki before 4.6.7 contains a server-side request forgery vulnerability in the Bazar valeur action that allows page editors to make the server fetch arbitrary URLs. Attackers can supply loopback or internal URLs in the url parameter to probe internal services and inject unescaped remote HTML that executes scripts in viewers' browsers.
CVE-2026-104874	New	5.3	MEDI				Multidict is an implementation of a multidict data structure. From 6.7.0 until 6.9.1, the C extension's items-view reflected union operation, operand d.items(), in multidict_itemsview_or2_impl and subtraction operation, d.items() - operand, in multidict_itemsview_sub1_impl fail to release new key-identity and value references returned for each operand element. Applications...
CVE-2026-104900	New	5.3	MEDI				MISP contains a stored cross-site scripting (XSS) vulnerability in the index table rendering of the remote event preview. The count field template escaped the associated link URL but rendered the field value without HTML encoding. An attacker with the ability to create or modify events on a linked (remote) MISP server could craft an event identifier containing HTML or JavaSc...
CVE-2026-104910	New	5.3	MEDI				MISP contains an authorization bypass in the related events listing functionality. When a user requests the list of events correlated to a given event, the system retrieved related event metadata directly from the correlation table without re-validating the caller's access rights against each related event. The correlation table stores a snapshot of the event's distribution...
CVE-2026-104914	New	5.3	MEDI				MISP contains an improper access control vulnerability in its attribute search and paginated attribute view endpoints. When a user queries for soft-deleted attributes (e.g., via the deleted-attributes search or the paginated attribute listing), the application returned soft-deleted attributes belonging to events owned by other organizations to any authenticated user who had...
CVE-2026-105030	New	5.3	MEDI				Kener 4.0.0 before 4.1.6 contains an information disclosure vulnerability that allows unauthenticated attackers to retrieve hidden or inactive monitor data by querying dashboard API handlers lacking visibility filters. Attackers can supply a known or guessed monitor tag to endpoints such as monitor-bar and monitor-latency-chart to obtain names, descriptions, status, uptime h...
CVE-2026-11795	New	5.3	MEDI				Observable discrepancy vulnerability in Softtr Informatics Trading Limited Company E-Commerce Pack allows Account Footprinting. This issue affects E-Commerce Pack: through 2026-10-02. NOTE: The vendor was contacted early about this disclosure but did not respond in any way.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12392	New	5.3	MEDI				An information exposure vulnerability in Canonical MAAS prior to versions 3.4.10, 3.5.14, 3.6.5, 3.7.3, and 3.8.0 allows an unauthenticated attacker to retrieve the RPC secret in plaintext via the vendor data metadata endpoint. If a target machine was deployed with the 'register as rack' option enabled, an attacker who obtains or infers the machine's system ID can query the ...
CVE-2026-13413	New	5.3	MEDI		0.002		The CMP – Coming Soon & Maintenance WordPress plugin before 4.1.20 does not correctly restrict access to the site while maintenance/coming-soon mode is enabled, allowing unauthenticated visitors to bypass the coming-soon page and reach the otherwise hidden site, including hidden published pages, by shaping the request so it is mistaken for a login request.
CVE-2026-17508	New	5.3	MEDI		0.004		In Bouncy Castle for Java before 1.86, several password-based key derivation entry points ran the KDF with cost parameters taken from the untrusted input being processed, without bounding them, so a small input could dictate an arbitrary amount of work before any password or integrity check could reject it. The affected paths are the RFC 9579 PBMAC1 MAC calculator builders, ...
CVE-2026-32584	New	5.3	MEDI				Insertion of Sensitive Information Into Sent Data vulnerability in Chiranjit Hazarika Smart One Click Setup – Complete Demo Import & Export smart-one-click-setup allows Retrieve Embedded Sensitive Data.This issue affects Smart One Click Setup – Complete Demo Import & Export: from n/a through 1.4.3.
CVE-2026-80337	New	5.3	MEDI		0.002		Missing Authorization vulnerability in HAVELSAN Inc. Sef - AI Chatbot Platform allows Accessing Functionality Not Properly Constrained by ACLs. This issue affects Sef - AI Chatbot Platform: before 2.1. NOTE: The vendor was contacted and it was learned that the product is not supported.
CVE-2026-82043	New	5.3	MEDI				UTMStack before 11.2.16 contains an account enumeration vulnerability that allows unauthenticated attackers to determine registered email addresses by observing differing HTTP responses from the POST /api/account/reset-password/init endpoint. Attackers can submit arbitrary email addresses and distinguish registered accounts, which return 200 OK, from unregistered accounts, w...
CVE-2026-90952	New	5.3	MEDI		0.002		The WP Edit Password Protected WordPress plugin before 2.0.7 does not enforce its site-wide access restriction on the WordPress REST API, allowing unauthenticated users to read the content of published posts and pages that the site's access mode was configured to hide.
CVE-2026-90987	New	5.3	MEDI		0.002		The Easy PayPal & Stripe Buy Now Button WordPress plugin before 2.0.6 does not derive the payment amount on the server, taking it from a client-supplied field, so an unauthenticated attacker sets an arbitrary lower price for a purchase.
CVE-2026-91020	New	5.3	MEDI		0.003		The WebToffee Gift Cards for WooCommerce WordPress plugin before 1.3.1 does not validate a user-supplied gift card amount server-side before using it as the cart-item price and store-credit coupon value, allowing unauthenticated users to submit an arbitrary or negative amount, bypassing the configured denominations and manipulating the order total to obtain products without ...
CVE-2026-94405	New	5.3	MEDI		0.003		Authorization Bypass Through User-Controlled Key vulnerability in Shahjada Download Manager allows Retrieve Embedded Sensitive Data. This issue affects Download Manager: from n/a through 3.3.71.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94432	New	5.3	MEDI		0.003		The Appointment Booking Plugin – LatePoint Calendar & Scheduling for WordPress plugin for WordPress is vulnerable to Insecure Direct Object Reference in versions up to, and including, 5.7.1 via the OsPaypalConnectController::create_order_for_transaction() action registered as a public (unauthenticated) route through wp_ajax_nopriv_latepoint_route_call. The handler loads an...
CVE-2026-5782	New	5.2	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Loglama.net TurkHotspot allows Reflected XSS. This issue affects TurkHotspot: through 2026-10-02. NOTE: The vendor was contacted and it was learned that the product is not supported.
CVE-2026-104466	New	5.1	MEDI				YesWiki before 4.6.7 contains a stored cross-site scripting vulnerability in formatters/wakka.php that allows users who can edit pages or post comments to inject event handlers by placing quotes in markdown image URLs. Attackers can store a crafted markdown image whose src breaks out of the attribute to add an onerror handler, executing JavaScript in viewers' browsers, inclu...
CVE-2026-104901	New	5.1	MEDI				MISP contains a cross-site scripting (XSS) vulnerability in the ID Translator feature. When a user views the ID Translator page, the application queries linked (remote) MISP servers for corresponding event identifiers. The event ID returned by the remote server was rendered in the HTML output without proper output encoding. A malicious or compromised linked server could ret...
CVE-2026-105090	New	5.1	MEDI				Formbricks before 5.4.4 and 6 before 6.0.1 allows stored XSS. The survey-level Custom Head Scripts feature did not enforce the documented Manage permission boundary. A workspace member holding only readWrite permission could configure Custom Head Scripts on a survey, an operation the documentation restricts to the Manage role. Because the configured scripts execute in the au...
CVE-2026-79113	New	5.1	MEDI				OpenAPV before 1.1.1.0 has a read_bitstream heap-based buffer overflow.
CVE-2026-94594	New	5.1	MEDI				Armatura One's message broker logs client connection credentials and the associated password in plain text during normal operation. Any party with read access to this log, or to a backup or support bundle that includes it, can obtain the logged credential.
CVE-2026-82040	New	5.0	MEDI				UTMStack before 11.2.16 contains a server-side request forgery vulnerability in IdentityProviderService.validateMetadataUrl() that allows authenticated attackers to make the server send requests to arbitrary internal or cloud metadata hosts by supplying a malicious metadata URL to the identity-providers endpoint. Attackers can exploit the POST/PUT /api/identity-providers end...
CVE-2026-101357	New	4.9	MEDI				The SEOPress – AI SEO Plugin & On-site SEO plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'seopress_google_analytics_matomo_id' parameter in all versions up to, and including, 10.2 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitra...
CVE-2026-80464	New	4.9	MEDI		0.003		Server-Side request forgery (SSRF) vulnerability in HAVELSAN Inc. Sef - AI Chatbot Platform allows Server Side Request Forgery. This issue affects Sef - AI Chatbot Platform: before 2.1. NOTE: The vendor was contacted and it was learned that the product is not supported.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104419	New	4.8	MEDI				Zebra (zebrad) 4.5.0 before 6.3.0 discards which peer supplied the block hashes in FindBlocks responses, then assigns 100 misbehavior points, the ban threshold, to whichever peer serves a requested block more than 50,000 heights above the tip. A remote peer can return real far-ahead hashes to a syncing node so that honest peers get banned, eroding its peer set and raising ec...
CVE-2026-104907	New	4.8	MEDI				MISP contains a cross-site scripting (XSS) vulnerability in the remote event preview page. When a linked (remote) MISP server is configured, the event preview renders tag identifiers inside an inline JavaScript onclick attribute. The tag ID value was HTML-escaped but not sanitized for the JavaScript string context, meaning a malicious linked server could supply a tag ID cont...
CVE-2026-59659	New	4.8	MEDI		0.004		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomZonaGeo" parameter is affected – endpoint "/es/geozones/update/149979".
CVE-2026-59660	New	4.8	MEDI		0.004		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomTransportista" parameter is affected – endpoint "/es/carriers/update".
CVE-2026-59661	New	4.8	MEDI		0.004		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomRuta" parameter is affected – endpoint "/es/routes/update/693".
CVE-2026-59662	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomCompetidor" parameter is affected – endpoint "/es/competitors/store".
CVE-2026-59663	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomDelegacion" parameter is affected – endpoint "/es/delegations/store".
CVE-2026-59664	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomServicioPrestado" parameter is affected – endpoint "/es/providedservices/store".
CVE-2026-59665	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomMotivo" parameter is affected – endpoint "/es/lostmotives/store".
CVE-2026-59666	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomOrigen" parameter is affected – endpoint "/es/origins/store".

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59667	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomTamano" parameter is affected – endpoint "/es/companysizeemployees/update".
CVE-2026-59668	New	4.8	MEDI				Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomTamano" parameter is affected – endpoint "/es/companysizebills/store".
CVE-2026-59669	New	4.8	MEDI		0.003		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "name" parameter is affected – endpoint "/es/attachmenttypes/update/203336"
CVE-2026-59670	New	4.8	MEDI		0.003		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomListaValidacion" parameter is affected – endpoint "/es/validationslists/assignList/Employee/45659".
CVE-2026-59671	New	4.8	MEDI		0.003		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The endpoint "/es/datatables/getemployeetypesdatatable" is affected.
CVE-2026-59672	New	4.8	MEDI		0.004		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomGrupoEmpresarial" parameter is affected – endpoint "/es/corporategroups/update/246".
CVE-2026-59673	New	4.8	MEDI		0.004		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomTipoCli" parameter is affected – endpoint "/es/clienttypes/update/109441".
CVE-2026-91784	New	4.8	MEDI		0.002		cjbassi/gotop is vulnerable to local argument injection via process termination functionality. The process name is passed directly to pkill without sanitization. A local attacker can create a process with a crafted name beginning with -- (e.g. containing a target user's UID). When the user running gotop invokes the kill feature on that process, pkill interprets the crafted n...
CVE-2026-95662	New	4.8	MEDI		0.004		Cross-Site Scripting vulnerability in the Repasat application. Successful exploitation of this vulnerability could allow an attacker to trick a user into executing arbitrary code in the victim's browser. The "nomCompetidor" parameter is affected – endpoint "/es/competitors/store".
CVE-2026-39600	New	4.7	MEDI				URL Redirection to Untrusted Site ('Open Redirect') vulnerability in Mehul Gohil Aculect AI Companion aculect-ai-companion allows Phishing.This issue affects Aculect AI Companion: from n/a through 0.8.1.
CVE-2026-104412	New	4.3	MEDI				Ghost 0.5.0 before 6.64.0 does not correctly restrict staff role assignment, allowing users with the Editor or Super Editor role to assign their own role to other staff despite lacking permission to do so. An authenticated Editor or Super Editor can promote Author and Contributor users to Editor or Super Editor.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104612	New	4.3	MEDI				A vulnerability was found in SourceCodester Student Result Management System 1.0. This affects an unknown part of the file script/academic/core/new_announcement.php of the component Announcement Module. The manipulation of the argument title/announcement results in cross site scripting. It is possible to launch the attack remotely. The exploit has been made public and could ...
CVE-2026-105029	New	4.3	MEDI				UVdesk support-center-bundle before 1.1.3.3 contains an insecure direct object reference vulnerability in the rateTicket action of Controller/Ticket.php that allows authenticated customers to rate other customers' tickets. Attackers can supply arbitrary ticket IDs, which are loaded without an ownership check, to submit or change satisfaction ratings on tickets owned by other...
CVE-2026-105046	New	4.3	MEDI				Kentico Xperience 13 before 13.0.216 lacks object-level authorization checks for administration API endpoints.
CVE-2026-11399	New	4.3	MEDI				The Helpdesk Support Ticket System for WooCommerce plugin for WordPress is vulnerable to Insecure Direct Object Reference in all versions up to, and including, 2.1.6 via the 'id' parameter due to missing validation on a user controlled key. This makes it possible for authenticated attackers, with subscriber-level access and above, to delete arbitrary ticket responses belongi...
CVE-2026-1661	New	4.3	MEDI		0.002		The WP Mail Logging WordPress plugin before 1.17.0 does not properly restrict the HTML and CSS of logged emails before rendering them in its admin log screens, allowing unauthenticated users to inject styled content and links, for example through a public contact form, that can deceive an administrator viewing the log and send their browser to an attacker-controlled page.
CVE-2026-39717	New	4.3	MEDI				Missing Authorization vulnerability in ThimPress LearnPress learnpress allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects LearnPress: from n/a through 4.4.9.1.
CVE-2026-51899	New	4.3	MEDI				In SuperAGI v0.0.14 and prior, controller endpoints (/api/agents/create, /api/agents/schedule, /api/agents/delete, /api/agents/edit_schedule, /api/agents/stop_schedule) allow authenticated users from one organization to create, schedule, edit, stop, and delete agents belonging to a different organization's project. The endpoints accept a project_id parameter but do not verif...
CVE-2026-79618	New	4.3	MEDI		0.002		The WP User Frontend WordPress plugin before 4.3.12 does not enforce its subscription-purchase requirement in one of its post-creation handlers, allowing authenticated users with subscriber-level access and above to create and, depending on the form's configuration, immediately publish posts through forms restricted to paying subscribers.
CVE-2026-91108	New	4.3	MEDI				The Alt Text AI – Automatically generate image alt text for SEO and accessibility plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 1.10.41. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with subscriber-level access and above, ...
CVE-2026-94180	New	4.3	MEDI		0.003		Authorization Bypass Through User-Controlled Key vulnerability in Monetizemore Advanced Ads allows Retrieve Embedded Sensitive Data. This issue affects Advanced Ads: from n/a through 2.0.26.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97219	New	4.3	MEDI		0.002		The MStore API WordPress plugin before 4.22.1 does not restrict which fields of an order a customer may update, allowing any authenticated user with a self-registerable account to change the status of their own unpaid order to a paid or fulfilled state and receive the goods without paying.
CVE-2026-105048	New	4.0	MEDI				The Playground feature of Zilliz Attu before 3.0.0 allows SSRF (proxying of requests to private IP addresses).
CVE-2026-105083	New	3.9	LOW				ImageMagick before 7.1.2-32 and 6.9.13-57 contains a policy bypass vulnerability in LoadPolicyCache that silently skips security policy rules when policy.xml uses an alternate DOCTYPE. A valid DOCTYPE not ending in '>' makes the parser consume the rest of the file, so no policy rules are applied and restricted operations become allowed.
CVE-2026-104424	New	3.7	LOW				Zebra before 6.1.0 contains an incorrect calculation vulnerability in its ZIP-317 block template selector that omits header and transaction-count size from the block budget. Attackers can place valid selectable transactions in a victim miner's mempool to shape templates into oversized blocks, causing rejection and wasted proof-of-work.
CVE-2026-39601	New	3.7	LOW				Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') vulnerability in WPdevelop Booking Calendar booking allows Leveraging Race Conditions.This issue affects Booking Calendar: from n/a through 11.8.4.
CVE-2026-105043	New	3.6	LOW				MathWorks Simulink before R2026b, when showing a crafted .slx file, can have blocks that are never visible in the Simulink Editor but will cause code execution.
CVE-2026-102002	New	3.1	LOW		0.003		The Otter Blocks – Gutenberg Blocks, Page Builder for Gutenberg Editor & FSE plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 3.2.6 via the 'otter_form_widget_filter' parameter. This makes it possible for authenticated attackers, with subscriber-level access and above, to extract the email addresses of the five most r...
CVE-2026-104994	New	2.5	LOW				Trivy before 0.71.0 allows directory traversal in Terraform filesystem functions when they try to access pathnames above the scan root. The risk occurs when using misconf scanning on untrusted input (e.g., upon a third-party pull request that contains a Terraform configuration), if sensitive data can be found at those unintended pathnames, and an adversary can then view a se...
CVE-2026-104415	New	2.3	LOW				Ghost from 0.7.2 before 6.64.0 contains an information disclosure vulnerability in the Admin API that allows staff-level users to determine the relative ordering of other staff users' password hashes. Authenticated staff users can query the Admin API to infer hash ordering, though this does not directly reveal hashes or enable practical password recovery.
CVE-2026-94486	New	2.3	LOW				Next.js is a React framework for building full-stack web applications. From 16.0.0 until 16.3.8, the next dev development server exposes a Model Context Protocol endpoint without reliably restricting cross-site requests. A malicious website visited by a developer can reach the endpoint and read the project's disk location, source code snippets from error reports, route inven...
CVE-2026-104606	New	2.1	LOW				A security flaw has been discovered in itsourcecode Online Admission System Project 1.0. The impacted element is an unknown function of the file confirm.php. The manipulation of the argument ID results in sql injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104613	New	2.1	LOW				A vulnerability was determined in CodeAstro Simple Pharmacy Management System 1.0. This vulnerability affects unknown code of the file /SimplePharmacy-PHP/product/view.php. This manipulation of the argument ID causes sql injection. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-104614	New	2.1	LOW				A vulnerability was identified in CodeAstro Simple Pharmacy Management System 1.0. This issue affects some unknown processing of the file /SimplePharmacy-PHP/product/delete.php. Such manipulation of the argument ID leads to sql injection. The attack can be launched remotely. The exploit is publicly available and might be used.
CVE-2026-104855	New	2.0	LOW			rust:wasmtime	Wasmtime is a runtime for WebAssembly. From 46.0.0 until 46.0.2 and 47.0.3, fuel and epoch preemption checks inside bulk operations including memory.copy, table.grow, and array.copy can expose invalid intermediate state when an embedder mutates a Store in Store::epoch_deadline_callback or continues using a Store after cancellation or a trap. A cancelled non-nullable table gr...
CVE-2026-105051	New	1.9	LOW				Denuvo Anti-Tamper through 2026-03-04 allows bypass of a hypervisor presence check via CPUID interception (SimpleSvm.sys on AMD; hyperkd.sys and hyperhvh.dll on Intel).
CVE-2026-10032	New		CRIT		0.001	npm:@a2ui/web_core	### Summary The `openUrl` function in `@a2ui/web_core` passes an agent-controlled URL directly to `window.open()` without validating the URI scheme. A malicious agent can supply a `javascript:` URI as the `url` argument of a `Button` component's `functionCall` action. When the user clicks the rendered button, arbitrary JavaScript executes in the victim application's browser...
CVE-2026-101159	New						The WP Ultimate Review WordPress plugin before 2.4.4 does not properly sanitise and escape reviews submitted through its public review form, which is available to unauthenticated visitors, allowing them to perform Stored Cross-Site Scripting attacks against any user, including administrators, viewing a page displaying the review, when user reviews are enabled.
CVE-2026-101160	New						The WP Ultimate Review WordPress plugin before 2.4.4 does not validate that a submitted review rating is numeric before storing it and later using it in numeric operations when rendering reviews, allowing unauthenticated users to make the reviewed content fail with a fatal error for all visitors until the review is removed (a persistent denial of service), when user reviews ...
CVE-2026-101161	New						The WP Ultimate Review WordPress plugin before 2.4.4 does not prevent unauthenticated users from storing crafted review content that makes the reviewed page fail with a fatal error on every subsequent visit, resulting in a persistent denial of service when the WP Ultimate Review WordPress plugin before 2.4.4's review display settings have never been saved.
CVE-2026-101162	New						The WP Ultimate Review WordPress plugin before 2.4.4 does not escape some of its review overview settings before outputting them in posts, which could allow users with a role as low as author to perform Stored Cross-Site Scripting attacks, when author reviews are enabled.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102731	New				0.002		Memory allocation with excessive size value vulnerability in Apache Directory LDAP API. A malicious peer (or a MITM) can send a small BER-encoded response causing a large memory allocation before any data is received. This can lead to an OutOfMemoryError and denial of service. The client JVM OOMs (OutOfMemoryError bypasses the DecoderException handlers) or pins the lar...
CVE-2026-103293	New						The MPG WordPress plugin before 4.2.3 does not validate that the dataset source supplied when importing a project is a remote URL before treating it as a local filesystem path and copying that file into a publicly accessible uploads folder. This makes it possible for users with the Editor role and above to read the contents of arbitrary files on the server, with the copied ...
CVE-2026-103514	New						The WP 2FA WordPress plugin before 4.1.0 does not invalidate a time-based one-time passcode once it has been used, allowing an attacker who knows an account's password and has observed a valid code within its validity window to replay it and bypass two-factor authentication, including on administrator accounts.
CVE-2026-103621	New						Integer overflow in Compositing in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to leak cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103623	New						Use after free in MediaStream in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103624	New						Use after free in Contextual Tasks in Google Chrome on on Windows prior to 154.0.8037.97 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103626	New						Incorrect authorization in FileSystem in Google Chrome on on Windows prior to 154.0.8037.97 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103627	New						Information leak in SVG in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-103629	New						Integer overflow in Skia in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to leak cross-origin data via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103630	New						Use after free in FedCM in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103631	New						Buffer overflow in WebRTC in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103877	New						Deserialization of Untrusted Data vulnerability in Apache Directory LDAP API. A rogue/compromised LDAP server (or pre-TLS MITM) can answer a client's loadSchema() subschema search with a schema object that contains a serialized Java class, allowing some potential RCE. This issue affects Apache Directory LDAP API: from 2.1.0 before 2.1.9. Users are recommended to up...
CVE-2026-103878	New						Cleartext transmission of sensitive information vulnerability in Apache Directory LDAP API. A StartTLS extended operation started after a Search request has been sent can lead to receive data in plain text before the TLS Handshake has been completed. This issue affects Apache Directory LDAP API: from 2.1.0 before 2.1.9. Users are recommended to upgrade to version 2....
CVE-2026-103880	New						Asymmetric Resource Consumption vulnerability in Apache Directory LDAP API. Storing a password using the bcrypt algorithm with a high force like 30 in a LDAP server that supports this algorithm will cause the server CPU to run for hours checking the credentials. A bounded cost should be enforced to avoid a server DOS. This issue affects Apache Directory LDAP API: from...
CVE-2026-103885	New						Asymmetric Resource Consumption vulnerability in Apache Directory LDAP API. A LDAP server using the LDAP API (like Apache DS) may consume 100% of a CPU core indefinitely when processing some badly crafted Telephone Numbers. This issue affects Apache Directory LDAP API: from 2.1.0 before 2.1.9. Users are recommended to upgrade to version 2.1.9, which fixes the issue.
CVE-2026-104886	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: CVE-2026-78410. Reason: This candidate is a duplicate of CVE-2026-78410. Notes: All CVE users should reference CVE-2026-78410 instead of this candidate
CVE-2026-104887	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: CVE-2026-78409. Reason: This candidate is a duplicate of CVE-2026-78409. Notes: All CVE users should reference CVE-2026-78409 instead of this candidate
CVE-2026-19481	New		HIGH		0.005	npm:@fastify/busboy	### Impact Versions of `@fastify/busboy` from 1.0.0 and prior to 3.2.1 are vulnerable to a Denial of Service. The multipart header parser stores part-header names on a plain JavaScript object, so a part header named `__proto__` or `constructor` resolves to an inherited value that is not an array, and the parser throws `TypeError: this.header[h].push is not a function`. Thro...
CVE-2026-19484	New		HIGH		0.006	npm:@fastify/busboy	### Impact Versions of `@fastify/busboy` from 3.1.0 and prior to 3.2.1 are vulnerable to a Denial of Service. The vendored streaming multipart search stores its default skip distance in a `Uint8Array(256)`. A multipart boundary of exactly 252 bytes makes the search needle 256 bytes, and the table entry wraps to zero, so a crafted request keeps the search in a CPU-bound loop...
CVE-2026-51898	New						sinaptik-ai pandas-ai 3.0.0 is vulnerable to Code Injection in CodeExecutor.execute.
CVE-2026-51901	New						SuperAGI up to 0.0.14 is vulnerable to Incorrect Access Control. The agent execution controller endpoint /api/agentexecutions/schedule allows authenticated users from one organization to schedule existing agents belonging to a different organization without proper authorization checks. The endpoint accepts an agent_id parameter but does not verify that the agent belongs to t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-51904	New						SuperAGI up to v0.0.14 contains an improper access control vulnerability in the agent execution controller. In affected source snapshots, create_agent_execution and create_agent_run in superagi/controllers/agent_execution.py accept a caller-supplied agent_id and fail to verify that the referenced agent belongs to the authenticated user's organization. A remote authenticated ...
CVE-2026-51906	New						In TaskingAI v0.3.0 in the DALL-E 3 image generation tool save_url_image function, a path traversal vulnerability allows attackers to write downloaded images to arbitrary locations on the server filesystem by manipulating the project_id parameter.
CVE-2026-51911	New						vanna v2.0.2 contains a code injection vulnerability in VannaBase.get_plotly_figure (src/vanna/legacy/base/base.py). Depending on the exposed entry, an attacker can trigger attacker-controlled code or command execution.
CVE-2026-51914	New						TransformerOptimus SuperAGI v0.0.14 is vulnerable to Incorrect Access Control in the agent template controller. In affected source snapshots, save_agent_as_template and publish_template in superagi/controllers/agent_template.py accept caller-supplied agent_id or agent_execution_id values and do not verify that the referenced agent or execution belongs to the authenticated us...
CVE-2026-51915	New						TransformerOptimus SuperAGI v0.0.14 is vulnerable to Incorrect Access Control in the tool controller. In affected source snapshots, get_tool and update_tool in superagi/controllers/tool.py accept a caller-supplied tool_id and fail to verify organization ownership through the associated toolkit. A remote authenticated attacker from one organization can read or modify another ...
CVE-2026-51917	New						FinRobot v1.0.0 is vulnerable to Code Injection in CodingUtils.modify_code.
CVE-2026-51918	New						FinRobot 1.0.0 contains code injection in CodingUtils.create_file_with_code ().
CVE-2026-51922	New						agentscope v1.0.20 contains code injection in execute_shell_command (src/agentscope/tool/_coding/_shell.py). Depending on the exposed entry, an attacker can trigger attacker-controlled code or command execution.
CVE-2026-59265	New						A code execution issue in the Java integration in Apache OpenOffice v4.1.16 and earlier allows a crafted untrusted document to trigger executing arbitrary (even remote) code when opened by the user. This issue is expected to be fixed in version 4.1.17, which is in the release candidate phase. Until then, users can mitigate this issue by disabling Java runtime integrati...
CVE-2026-61586	New		HIGH			Maven:eu.copernik:copernik-xml-factory	Copernik XML Factory through `0.1.1`, when running on its stock JDK provider, does not block XInclude resource resolution after an application enables XInclude on a factory returned by `XmlFactories.newDocumentBuilderFactory()` or `XmlFactories.newSAXParserFactory()`, or on an `XMLReader` passed through `XmlFactories.harden()`. The library's documented guarantee that XInclud...
CVE-2026-62314	New		MODE		0.005	Go:github.com/TecharoHQ/anubis	Any HTTP client can bypass Anubis bot protection on the default configuration by adding a single request header. No challenge needs to be solved. Affected versions: v1.22.0 through v1.25.0 (introduced in commit d1d631a, PR #1015) The root cause is in `lib/policy/checker.go`, `PathChecker.Check()`: ``go func (pc *PathChecker) Check(r *http.Request) (bool, error) { origi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-64818	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-71416	New		HIGH		0.002	PyPI:headroom-ai	### Summary The Headroom WebSocket server does not validate the `Origin` header of incoming client WebSocket requests before forwarding the request to the upstream server, allowing malicious WebSocket clients to perform arbitrary LLM requests without authentication. This can be exploited by a malicious WebSocket client executed in a traditional or headless browser such as li...
CVE-2026-73802	New		CRIT			Go:gitea.com/gitea/runner	### Summary act_runner appends workflow-controlled `jobs.<job>.container.options` directly to the Docker HostConfig for the job container. When runner privileged mode is disabled, only `Privileged` is forced false. Host namespace flags, capability expansion, and security profile overrides from workflow YAML are preserved in the final HostConfig. A workflow author can ent...
CVE-2026-74802	New		LOW		0.002	Go:github.com/siyuan-note/siyuan/kernel	**High** ## Package gomod `github.com/siyuan-note/siyuan/kernel` ## Affected versions 3.7.3 ## Patched versions *(none yet — leave blank until a fix is released)* ## Description ### Summary `/ws/network/proxy` is an admin-only WebSocket forward-proxy endpoint (target URL and headers fully attacker-specifiable via query parameters). Its `websocket.Upgrader` explicitly ov...
CVE-2026-74904	New		HIGH		0.005	Go:github.com/siyuan-note/siyuan/kernel	Same CWE-862 family, found via an automated bulk sweep of every `/api/block/*` handler in `kernel/api/block.go` for the presence of any access-check reference (`IsReadOnlyRoleContext`, `checkBlockPublishAccess`, `GetPublishAccess`) anywhere in the function body. 17 of 28 candidate endpoints have none. Cross-checked against the file's own sibling functions (`getBlockInfo`, `g...
CVE-2026-80517	New						The WP Ultimate CSV Importer WordPress plugin before 9.2 does not properly validate the file types contained in an uploaded archive nor sanitise their content before storing them in a publicly served location, allowing high privilege users such as administrators to achieve Stored Cross-Site Scripting. On Multisite installations a site Administrator does not hold the unfile...
CVE-2026-80518	New						The WP Ultimate CSV Importer WordPress plugin before 9.2 does not use a site-specific secret when deriving the storage location of the import logs it writes under the uploads directory, nor does it block direct access to them, allowing unauthenticated attackers to retrieve the personal data of users imported from a CSV file.
CVE-2026-82233	New		MODE		0.004	Go:github.com/siyuan-note/siyuan/kernel	# Security Advisory — SiYuan MCP `asset.upload` Reads Arbitrary Absolute File Paths (Workspace Boundary Bypass) Field Value --- --- **Disclosed by** joysinleung (joysinleung@gmail.com) **Report date** 2026-08-13 **Product** SiYuan (■■■■■) — `siyuan-note/siyuan` **Go module** `github.com/siyuan-note/siyuan/kernel` **Affected versions** `<...`
CVE-2026-82234	New		HIGH		0.004	Go:github.com/siyuan-note/siyuan/kernel	# Security Advisory — SiYuan Agent Tools SSRF via DNS-Rebinding TOCTOU (Bypass of `CheckHostSSRF`) Field Value --- --- **Disclosed by** joysinleung (joysinleung@gmail.com) **Report date** 2026-08-13 **Product** SiYuan (■■■■■) — `siyuan-note/siyuan` **Go module** `github.com/siyuan-note/siyuan/kernel` **Affected versions** `<= 3.8.0` (lat...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85015	New						The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not sanitise file paths inside uploaded archives before extracting them, allowing authenticated users with access to its asset-management feature (Administrators by default, or Editors when a non-default Unlimited Elements for Elementor WordPress plugin before 2.0.21 setting is enabled) to write arbitra...
CVE-2026-85568	New						The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not correctly handle a search value before rewriting an already prepared SQL statement, allowing unauthenticated users to perform SQL injection attacks and to retrieve non-public content, when a related widget option is set away from its default.
CVE-2026-85650	New		HIGH		0.003	npm:trigger.dev	### Summary A project member can create a webhook alert channel whose delivery URL points at an internal address, and trigger.dev's control plane will send the alert there with no SSRF protection. The webhook URL is stored as an unvalidated string and is fetched directly from the webapp server, so a low-privilege authenticated user can make the server issue POST requests to ...
CVE-2026-85651	New		HIGH		0.005	npm:trigger.dev	### Summary The dashboard replay action authorizes the source run (it must belong to the caller's org), but the target environment for the replayed run is taken verbatim from the request body and is never checked for org or project membership. The environment lookup used by the replay path filters by id only. As a result, an authenticated user can replay one of their own run...
CVE-2026-86832	New						The MetForm WordPress plugin before 4.3.1 does not properly restrict access to form submission data, allowing unauthenticated attackers to view submitter information through the REST API.
CVE-2026-86834	New						The MetForm WordPress plugin before 4.3.1 does not properly restrict access to a debug file it writes to the web root on every form submission when its HubSpot Forms integration is enabled, allowing unauthenticated attackers to read upstream API response data, including correlation identifiers and cookies.
CVE-2026-88782	New						The Kubio AI Page Builder WordPress plugin before 2.9.3 does not validate the URI scheme of a user-supplied value before outputting it as a link target, allowing users with the contributor role and above to store a payload which executes in the browser of anyone who follows the link, including an administrator previewing the unpublished submission.
CVE-2026-88783	New						The Kubio AI Page Builder WordPress plugin before 2.9.3 does not limit its widening of the allowed HTML elements to the editor context, so the wider set is applied when filtering content submitted by unauthenticated users as well, allowing them to store markup which the Kubio AI Page Builder WordPress plugin before 2.9.3's own script later executes in the browser of any visi...
CVE-2026-89236	New						The SaveTo Wishlist Lite WordPress plugin before 1.1.5 does not sanitise and escape parameters before using them in the ORDER BY clause of a SQL query, allowing unauthenticated attackers to append additional SQL queries and extract sensitive information from the database.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91078	New						The TillKit WordPress plugin before 1.0.5 does not require the hard-coded, publicly known PIN of the privileged POS account it creates on activation to be changed before use, and it authenticates its public POS login endpoint on that PIN alone with no identity or capability check, allowing unauthenticated attackers to obtain a privileged POS session and thereby read customer...
CVE-2026-92437	New						The Mailchimp for WooCommerce WordPress plugin before 6.3 does not require authentication, a nonce or an ownership check before it acts on a customer's abandoned-cart record identified from request-supplied data, allowing an unauthenticated attacker to modify or delete another customer's stored cart.
CVE-2026-92923	New						The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not sanitise and escape a parameter before using it in a SQL statement, allowing users with a role as low as subscriber to perform blind SQL injection attacks and read arbitrary data from the database. Version 2.0.18 removed the subscriber-level access, so from 2.0.18 onward the issue requires a Contrib...
CVE-2026-94238	New						The Loco Translate WordPress plugin before 2.8.9 does not restrict which file paths its translation file routes will read, allowing users granted the Loco Translate WordPress plugin before 2.8.9's translator capability to retrieve the contents of files of certain types from anywhere on the server, including outside the web root.
CVE-2026-94239	New						The Loco Translate WordPress plugin before 2.8.9 does not sanitise and escape some bundle configuration values before outputting them back in an admin page, allowing users with the translator capability and above to perform Stored Cross-Site Scripting attacks against high privilege users such as administrators.
CVE-2026-96962	New						The Pie Register WordPress plugin before 3.8.4.14 does not restrict access to an invitation-code report, allowing unauthenticated visitors who know a valid invitation code to obtain the username and email address of every user who registered with that code.
GHSA-325f-rjxf-3gm9	New					npm:ui.dist.min.js	--- _-= Per source details. Do not edit below this line._= _ ## Source: ghsa-malware (cf50ae695b73c6662269893d9ac1f677ce5be474e9648bfa23cdfb35b1b04a3c) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-35mr-4567-66vg	New		MODE			PyPI:dulwich	### Affected file * `dulwich/pack.py` (Method: `Pack.resolve_object`) ### Description / Summary A High-severity Denial of Service (DoS) vulnerability exists in the `Pack.resolve_object` method. When resolving an `OFS_DELTA` object, the resolver calculates the base offset using `base_offset = obj_offset - delta_offset`. If a malicious packfile contains an `OFS_DELTA` object...
GHSA-4672-hwv6-gq62	New		MODE			npm:trigger.dev	### Summary Trigger.dev isolates each project into multiple **environments** (`dev`, `staging`, `prod`, and per-PR `preview` branches), each with its **own secret API key** — the environment is a trust boundary (a `dev`/preview/CI key is lower-trust than a `prod` key). Most API routes enforce this by scoping resource lookups to the authenticated key's environment (`where: {...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-59h8-w5q6-mfmp	New		MODE			npm:trigger.dev	## Summary The POST handler for `/realtime/v1/streams/:runId/:streamId` has no authentication. Any entity that knows or guesses a run friendlyId can inject arbitrary data into its realtime stream. ## Vulnerability Details **File:** `apps/webapp/app/routes/realtime.v1.streams.\$runId.\$streamId.ts` The `action` handler (line 17) has no auth wrapper. The code comment says: "...
GHSA-5fqc-mrg8-w798	New		HIGH			PyPI:dulwich	## Summary Dulwich's `filter_branch.py` `CommitFilter._apply_index_filter()` is vulnerable to symlink directory traversal. When processing commit history, materialized tree entries (including symlinks) persist in the working directory between commits, allowing a symlink from an ancestor commit to redirect file writes from a descendant commit to arbitrary filesystem location...
GHSA-5rmq-chc7-m22f	New		HIGH			PyPI:vibe-trading-ai	#### Summary: 2 findings — `safe_user_path()` accepts any path under `Path.home()` or `Path.cwd()`, which inside the shipped root container resolves to `/root` and `/app` (so all of root's home, including `/root/.ssh/id_rsa`, `/root/.aws/credentials`, `/root/.kube/config`, and `/app/agent/.env`, passes the check) (F9). `read_document()` has no sandbox call at all and returns...
GHSA-5wf9-h793-w73c	New		HIGH			Go:github.com/xtls/xray-core	#### Summary Pinning a CA certificate via `pinnedPeerCertSha256` can lead to the success of MITM attacks in some cases. #### Details https://github.com/XTLS/Xray-core/blob/45cf2898ab12e97a55dd8f1f3d78d903340bdc9e/transport/internet/tls/config.go#L333-L347 If `r.Config.ServerName` is empty, `DNSName` will be empty and `certs[0].Verify(opts)` will not verify against dNSName ...
GHSA-8mcx-5rqc-vhmf	New		HIGH			PyPI:dulwich	#### Affected files * `dulwich/index.py` (Methods: `validate_path_element_ntfs`, `_tree_to_fs_path`) * `dulwich/porcelain/_init_.py` (Method: `_checked_worktree_path`) #### Description / Summary A High-severity Path Traversal vulnerability exists in Dulwich's checkout logic when running on Windows. The functions responsible for validating NTFS paths strictly reject `.git` v...
GHSA-8w8g-wq8h-fq33	New		HIGH			PyPI:dulwich	## Summary Dulwich's `porcelain.checkout(paths=[...])` code path writes files using raw `os.open(file_path, O_WRONLY O_CREAT O_TRUNC, mode)` followed by `f.write(obj.data)`. This code path does NOT call `build_file_from_blob()` at all, completely bypassing any symlink protections (including the unreleased d09f8af fix). `os.open` without `O_NOFOLLOW` follows symlinks at both...
GHSA-9q4r-4842-93vw	New		HIGH			npm:trigger.dev	#### Summary A cross-tenant SQL injection in the TSQL query compiler lets **any authenticated trigger.dev customer read every other tenant's analytics data**. The customer-facing query endpoint `POST /api/v1/query` accepts a TSQL/TRQL query that is compiled to ClickHouse SQL by `internal-packages/tsql`. The compiler parameterizes or escapes all user input and injects a per-t...
GHSA-cm62-gvxx-vmxx	New		HIGH			PyPI:dulwich	## Summary Dulwich's `stash.py:pop()` function is vulnerable to symlink directory traversal, allowing an attacker to write arbitrary files outside the repository worktree when a victim pops a stash in a malicious repository. ## Root Cause The `pop()` function at `dulwich/stash.py:236` uses `os.path.exists(parent_dir)` to check if a parent directory exists before writing s...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-fj2x-mqgp-3v2w	New		MODE			npm:trigger.dev	Affected version: trigger.dev 4.5.3 (4.5.6 was advertised by the CLI but was not tested). A staging dry-run executed with `trigger.dev deploy --env staging --dry-run --log-level debug`. The debug output logged the complete build-worker options object. Its `envVars` property contained unredacted values for every resolved staging variable, including database connection string...
GHSA-gg6r-gp4c-89hp	New		CRIT			npm:trigger.dev	## TL;DR The /coordinator Socket.IO namespace mounts on every webapp boot and authenticates with a default secret ("coordinator-secret") baked into source. The override variable isn't documented in the self-host docs, .env.example, or helm values, so any operator who didn't read source ships with the default. Once connected, READY_FOR_EXECUTION returns the run's decrypted e...
GHSA-grv5-7wp6-vw6h	New					npm:translate-base-font	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (d0ae1970321abd04ddd957d3135ee1d2eb64acee031428fa8f3cbcb8c48504b0) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-jqmf-mx4f-hfr6	New		CRIT			PyPI:vibe-trading-ai	### Summary: 5 findings — `BashTool` shell-injection sink (F6, the canonical RCE primitive), `BackgroundRunTool` async shell-injection sink (F7), backtest `exec_module()` runs top-level statements before the `SignalEngine` class check (F8 — independent RCE path that does not match BashTool signatures), `read_url` outbound HTTP forwarding without schema/host validation (F-B4...
GHSA-pp95-gc86-jq6q	New		HIGH			npm:trigger.dev	### Summary The run replay `action` function at `apps/webapp/app/routes/resources.taskruns.\$runParam.replay.ts` has no authentication or authorization check. While the `loader` (GET) in the same file properly calls `requireUser(request)` and scopes queries to the user's organizations, the `action` (POST) at line 166 does neither — allowing any authenticated user to replay t...
GHSA-pqwx-g93w-hj9x	New		HIGH			npm:trigger.dev	## Summary Self-hosted trigger.dev v4 instances deployed using the provided Docker Compose configuration with default secrets from `hosting/docker/.env.example` are vulnerable to a multi-stage unauthenticated attack chain leading to complete infrastructure compromise. ## Vulnerability Details The `hosting/docker/.env.example` file contains hardcoded cryptographic secrets:...
GHSA-q567-cr4x-96w4	New		MODE			npm:trigger.dev	### Summary A WEBHOOK alert channel stores a user-supplied `url`. When an alert fires (deployment/run failure, error groups), the webapp server (`alertsWorker` -> `DeliverAlertService`) POSTs the HMAC-signed alert payload to that URL via `fetch(webhook.url, ...)`. The URL is never validated against a host allowlist or private-IP/metadata blocklist (a repo-wide search for `1...
GHSA-qgqx-3mhx-jwx3	New					npm:ui-base-colors	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (1f7251d8342fbc78bb25925a713153e0bd22f820c678fde7e2ffa0db10fbd151) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-v2f8-6655-7grj	New		CRIT			PyPI:vibe-trading-ai	### Summary: 5 findings — unauthenticated full-API exposure (F1, lead Critical), read-side authorization gap that persists even with `API_AUTH_KEY` set (F2), unauthenticated file write of `.py'/.sh'/.yaml` to a server-returned path (F3), default-permissive CORS that combines with a loopback-only check to grant any browser page on whitelisted localhost ports credentialed c...
MAL-2026-17455	New					PyPI:dedh-devops-automation	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (e623272b4de65cc8af24a44d5405d9f6baa2c42896b50f9b7e0e5f294bfd2722) During installation, the package deploys a rogue AWS Lambda function to collect credentials from Secret Manager as well as collect other data. Data are then exfiltrated. --- Category: MALICIOUS - The campaign has clearly malici...
MAL-2026-17456	New					npm:@smwebserver/static	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ossf-package-analysis (11c6a6260058ce71a6f2c50eec8080c2b6e7c2fd8da807cb38e631e7ed9a15d5) The OpenSSF Package Analysis project identified '@smwebserver/static' @ 99.9.1 (npm) as malicious. It is considered malicious because: - The package communicates with a domain associated with malicious activity.
MAL-2026-17457	New					PyPI:voxeval	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (4ffc5162b3b77de40988aa702c4493260a4f0b4f09d5f4719feabcd69f33908a) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17461	New					PyPI:voxel-tts	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (59ef2094ba4f759a0f896ff0af35b1fd19442db3cf8212a39fde46d5713c807d) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...
MAL-2026-17462	New					PyPI:echogen	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (c38ef1a445f502de507bc9e58f66539c816eb765a086e14631bd164bc501a644) Installing the package or importing the module exfiltrates basic information about the host, and the package has no other purpose. --- Category: PROBABLY_PENTEST - Packages looking like typical pentest packages, but also anythi...
MAL-2026-17463	New					PyPI:voxcpmmts3	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (382411a9cc0ee358dbd8efcf17c5a943fc496fc4f2c86ffdc8f87d7efc43ec2d) The package imitates real activity and instead deploys a coin miner. --- Category: MALICIOUS - The campaign has clearly malicious intent, like info stealers. Campaign: 2026-10-voxeval Reasons (based on the campaign): - cr...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103764	Updated - CVSS changed (9.8 → 9.3)	9.3	CRIT		0.006		Mooncake transfer engine before 0.3.13 contains an untrusted pointer dereference in ServerSession::readHeader that allows unauthenticated attackers to read and write arbitrary process memory via the TCP transport data port. Attackers can send a crafted SessionHeader with arbitrary addr and size values using READ or WRITE opcodes to disclose KV cache contents, prompts and sec...
CVE-2026-103765	Updated - CVSS changed (9.4 → 8.8)	8.8	HIGH		0.005		Mooncake through 0.3.13.post1 contains a missing authentication vulnerability in the HTTP metadata server /metadata handler that allows unauthenticated attackers to read, overwrite, and delete transfer engine metadata keys. Attackers can poison segment descriptors such as tcp_data_port or re-create rpc_meta entries to redirect KV cache transfers to attacker-controlled listen...
CVE-2026-102997	Updated - CVSS vector changed	8.7	HIGH		0.003		pypdf is a free and open-source pure-python PDF library. Prior to 6.18.1, a crafted PDF containing a partially malformed /FlateDecode stream with padded data can force pypdf/filters.py to use inefficient byte-by-byte decompression while the earlier recovery counter fails to advance for bytes that successfully decode, causing long runtimes and application unavailability. This...
CVE-2026-103766	Updated - CVSS changed (7.2 → 8.6)	8.6	HIGH		0.004		ClipBucket v5 through 5.5.3-#197 contains an sql injection vulnerability that allows authenticated users with ad_manager_access permission to inject SQL via the delete parameter in admin_area/ads_manager.php. Attackers can supply time-based blind payloads concatenated into AdsManager::DeleteAd queries to extract user credentials and emails or modify and delete arbitrary reco...
CVE-2026-103760	Updated - CVSS changed (5.9 → 8.2)	8.2	HIGH		0.004		Mooncake transfer engine through 0.3.13.post1 contains a denial of service vulnerability that allows unauthenticated remote attackers to block the handshake daemon by never reading replies. Attackers can send a Metadata request to the handshake RPC port and stall SocketHandShakePlugin's single listener thread in writeFully(), breaking all subsequent handshakes, metadata fetc...
CVE-2026-104356	Updated - CVSS changed (5.9 → 8.2)	8.2	HIGH		0.003		PictShare before version 3.7.1 contains a weak randomness vulnerability where the getRandomString() function uses the non-cryptographic rand() PRNG to generate the delete_code authorization token in src/inc/core.php. Attackers can predict or infer the PRNG state to guess valid delete_code values and perform unauthorized deletion of hosted files without needing to read the co...
CVE-2026-96780	Updated - Fix/version updated	8.2	HIGH		0.004	npm:figlet	### Impact A denial-of-service (infinite loop) can occur in `text()` / `textSync()` when both : - `whitespaceBreak: true` is set, and - `width` is set smaller than the rendered width of a single FIGlet character. Under these conditions `breakWord()` could never find a valid break point, so the word-wrapping loop in `generateFigTextLines()` never terminated. This pins ...
CVE-2026-102831	Updated - CVSS added	8.1	HIGH		0.002		JupyterLab is an extensible environment for interactive and reproducible computing, based on the Jupyter Notebook Architecture. From JupyterLab 4.5.0 until 4.5.11 and 4.6.4, from Notebook 7.5.0 until 7.6.3, and from JupyterLite Core 0.7.0 until 0.8.4, the system clipboard cell-paste path accepts attacker-controlled cell JSON without clearing metadata.trusted. When useSystemC...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-71427	Updated - CVSS changed (6.8 → 7.6)	7.6	HIGH		0.003		Office-PowerPoint-MCP-Server through 2.0.7 contains a path traversal vulnerability that allows MCP callers to write and read files outside the working directory by supplying absolute paths or ../ sequences. Attackers can steer an AI agent via prompt injection to abuse save_presentation, open_presentation, or manage_image output_path to overwrite any server-writable file or l...
CVE-2026-102993	Updated - CVSS changed (8.7 → 7.5)	7.5	HIGH		0.003	pypdf_project:pypdf	pypdf is a free and open-source pure-python PDF library. Prior to 6.17.0, a crafted PDF can provide unusually large Roman page-label values that cause pypdf/_page_labels.py to generate excessively large numeral strings when an application retrieves document page labels, consuming large amounts of memory and potentially making the application unavailable. This issue is fixed ...
CVE-2026-91828	Updated - CVSS added	7.5	HIGH		0.002		The OMGF GDPR/DSGVO Compliant, Faster Google Fonts. Easy. WordPress plugin before 6.3.11 does not require authentication or a valid nonce on an action that issues a slow server-side loopback request, allowing unauthenticated attackers to exhaust the site's PHP worker pool and make the entire site unavailable.
CVE-2026-102937	Updated - CVSS added	7.3	HIGH		0.001		virtualenv is a tool for creating isolated virtual python environments. Prior to 21.7.12, BatchActivator.quote() returns prompt text unchanged before activate.bat inserts it into a cmd.exe set "VAR=value" statement. An attacker who influences --prompt, VIRTUALENV_PROMPT, or the corresponding configuration value can include a double quote that closes the assignment and leaves...
CVE-2026-104059	Updated - CVSS changed (8.1 → 7.0)	7.0	HIGH		0.001		Lektor 3.3.14 and 3.4.0b15 contains a cross-site request forgery vulnerability in the admin API blueprint that allows unauthenticated attackers to perform state-changing actions by sending cross-origin requests without CSRF tokens, Origin/Referer validation, CORS configuration, or Host allowlisting. Attackers can exploit the newattachment, deleterecord, build, clean, and pub...
CVE-2026-13718	Updated - CVSS added	6.8	MEDI		0.002		The Tabs Responsive WordPress plugin through 2.5 does not sanitize the content of WooCommerce product tabs before storing and rendering it, allowing a shop manager to store JavaScript that executes when any user, including an administrator, views the product page.
CVE-2026-85016	Updated - CVSS added	6.8	MEDI		0.002		The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not escape an icon value before concatenating it into an HTML attribute in its shared widget-parameter processor, allowing users with Contributor access (who do not hold unfiltered_html) to store a payload that executes when the page is rendered.
CVE-2026-91022	Updated - CVSS added	6.8	MEDI		0.002		The Motors WordPress plugin before 1.4.124 does not sanitise and escape a listing badge setting before outputting it inside an HTML attribute, allowing users with a custom, administrator-assigned listing-management role to inject arbitrary web scripts that execute when a listing is viewed by any visitor, including an administrator.
CVE-2026-51895	Updated - CVSS added	6.5	MEDI		0.001		Ragflow 0.24.0 and prior contains improper access control in update_metadata_setting (api/apps/kb_app.py). Depending on the exposed entry, an attacker can perform unauthorized cross-session or privilege-crossing operations.
CVE-2026-94298	Updated - CVSS added	6.2	MEDI		0.002		The BuildKit WordPress plugin before 1.0.29 does not properly sanitise and escape data submitted by contributor-level users before storing it and later using it in a SQL query, allowing a Contributor to inject SQL that runs against the database once the resulting content is published and viewed by any unauthenticated visitor.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97318	Updated - CVSS added	6.1	MEDI		0.001		The Giveaways and Contests by RafflePress WordPress plugin before 1.12.27 does not properly validate a giveaway's parent page URL before saving it and later redirecting visitors to it, allowing unauthenticated attackers to make the site's own giveaway confirmation and referral links redirect visitors to an arbitrary external site.
CVE-2026-104123	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A vulnerability was detected in SourceCodester Online Reviewer Management System 1.0. Affected by this vulnerability is an unknown functionality of the file <code>/reviewer_0/admins/assessments/activities/btn_functions.php?action=activity</code> . The manipulation of the argument Title results in sql injection. The attack may be launched remotely. The exploit is now public and may be used.
CVE-2026-81740	Updated - CVSS added	5.3	MEDI		0.001		The Paytm Payment Gateway WordPress plugin before 2.8.9 does not verify that payment callbacks genuinely originate from the payment provider when its secret key has not been configured, which is its state immediately after activation, allowing unauthenticated attackers to change the status of arbitrary orders, including marking unpaid orders as paid and reducing stock.
CVE-2026-90988	Updated - CVSS added	5.3	MEDI		0.001		The Request a Quote WordPress plugin through 2.5.6 does not perform an authorization check on one of its unauthenticated AJAX handlers, allowing unauthenticated users to read the contact records of quote-request submissions, including records the site has not published.
CVE-2026-97317	Updated - CVSS added	5.3	MEDI		0.001		The Giveaways and Contests by RafflePress WordPress plugin before 1.12.27 does not remove the reCAPTCHA secret key from the giveaway settings it embeds in public giveaway pages, allowing unauthenticated visitors to retrieve the secret key of any active giveaway that has reCAPTCHA configured.
CVE-2026-85004	Updated - CVSS added	4.3	MEDI		0.001		The Popup Maker WordPress plugin through 1.4.5 does not perform a capability check on one of its account-connection actions, only verifying a nonce, allowing authenticated users with minimal privileges such as Subscribers to overwrite a site-wide Popup Maker WordPress plugin through 1.4.5 option (the linked service account and API configuration) that should only be modifia...
CVE-2026-91023	Updated - CVSS added	3.1	LOW		0.001		The Motors WordPress plugin before 1.4.124 does not properly verify that a user is authorised to modify a listing before processing one of its listing management actions, allowing authenticated attackers with subscriber-level access and above to set metadata on posts they do not own, including overwriting product prices. Exploitation is possible only when WooCommerce is act...
CVE-2026-104053	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A vulnerability was identified in itsourcecode Pet Shop Management System 1.0. The impacted element is an unknown function of the file <code>admin_reservefilter.php</code> . Such manipulation of the argument filter leads to sql injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used.
CVE-2026-104054	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A security flaw has been discovered in calcom cal.diy up to 6.2.0. This affects the function <code>doesUserIdHaveAccessToBooking</code> of the file <code>BookingAccessService.ts</code> of the component PBAC Permission Engine. Performing a manipulation results in missing authorization. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks. The pu...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77387	Updated - Fix/version updated		MODE		0.002	pip:geopy	### Impact `geopy.Point` and `Point.from_string()` may take excessive CPU time when parsing long, malformed coordinate strings due to inefficient regular-expression behavior. The numeric Point constructor is not affected. Geocoders' `reverse` methods called with string inputs exercise the vulnerable path. Applications are affected when they pass attacker-controlled string...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102489	Added to KEV			Yes	0.006	zammad gmbh:zammad	Zammad GmbH Zammad contains a session fixation vulnerability that can lead to remote code execution as the zammad user. This vulnerability can be chained with CVE-2026-102490.
CVE-2026-102490	Added to KEV			Yes	0.003	zammad gmbh:zammad	Zammad GmbH Zammad contains an improper privilege management vulnerability that can allow the local zammad user to escalate privileges to root. This vulnerability can be chained with CVE-2026-102489.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103956	New	10.0	CRIT				Missing authentication for critical function in the authentication dependency in Loom for AWS before 1.6.1 allowed remote actors to obtain super-admin authority over the agent control plane, including registering tool servers, reading stored integration credentials, and rewriting the IAM role policies attached to managed agent roles, via any request to the application API in...
CVE-2026-82041	New	9.9	CRIT				UTMStack before 11.2.16 contains a missing authorization vulnerability in UTMIncidentCommandWebsocket.processCommand(), the handler mapped to the /command/{hostname} STOMP destination, where no role check or command allowlist is applied before forwarding supplied commands. Any authenticated user, regardless of role, can send arbitrary operating-system commands over gRPC to a...
CVE-2026-90970	New	9.9	CRIT				GitLab has remediated a vulnerability in the GitLab AI Gateway component affecting all versions of the AI Gateway from 18.1.6 before 19.2.4, 19.3 before 19.3.2, and 19.4 before 19.4.1 that, under certain conditions, could have allowed an authenticated user with Duo Agent Platform access to escape the prompt template sandbox via a specially crafted flow configuration, resulti...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93698	New	9.9	CRIT		0.005		Insufficient validation allows arbitrary commands to be executed via the Multilang adminbin.
CVE-2023-54405	New	9.8	CRIT				H3C CVM, the Cloud Virtualization Management component of the H3C CAS cloud platform, contains an unauthenticated arbitrary file upload vulnerability in the /cas/fileUpload/upload endpoint that allows remote attackers to write arbitrary files by manipulating the caller-supplied token parameter without restricting path traversal or file type. Attackers can exploit the path tr...
CVE-2026-104846	New	9.8	CRIT				Seroval facilitates JS value stringification, including complex structures beyond JSON.stringify capabilities. From 0.12.0 until 1.6.2, fromJSON deserialization of a fulfilled Promise control node can pass a plugin-produced callable-bearing thenable to a native Promise resolver. ECMAScript thenable assimilation then invokes the callable unexpectedly, allowing attacker-contro...
CVE-2026-19652	New	9.8	CRIT				The Divi Membership plugin for WordPress is vulnerable to Privilege Escalation in versions up to, and including, 2.2.0. This is due to the `dmem_form_submit_handler()` function determining the new user's role by iterating all WordPress roles and calling `password_verify()` against an attacker-controlled bcrypt hash supplied in the `form_id` POST parameter, with no validation...
CVE-2026-82042	New	9.8	CRIT				UTMStack before 11.2.16 contains an authentication bypass vulnerability that allows remote attackers to gain full administrative API access by presenting a valid Utm-Internal-Key header matching the INTERNAL_KEY environment variable value, which the InternalApiKeyFilter accepts for any endpoint without path restriction, constant-time comparison, rate limiting, or audit loggi...
CVE-2026-94541	New	9.8	CRIT		0.005		The WPMobile.App – Android and iOS App Builder plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 11.82 This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to exfiltrate password-reset URLs for arbitrary users, including administrato...
CVE-2026-97637	New	9.8	CRIT		0.006		The JSON API Auth plugin for WordPress is vulnerable to Authentication Bypass via Cached Session Cookie Disclosure in all versions up to, and including, 3.1.2. The vulnerability exists because the required PI-Media/json-api parent plugin caches controller dispatch results in transients keyed solely by URI and query string, ignoring HTTP method and POST body; this causes the ...
CVE-2026-103628	New	9.6	CRIT				Out of bounds write in WebGL in Google Chrome prior to 154.0.8037.97 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-104848	New	9.5	CRIT				Tinypool is a minimal Node.js worker thread pool implementation. Prior to 2.1.1, Tinypool constructs ThreadPool.options from a normal options object and reads the execArgv and env worker options in dist/index.js, allowing values inherited from a polluted Object.prototype to be copied into own properties and passed to worker_threads.Worker. An attacker who can first pollute e...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104849	New	9.5	CRIT				Tinypool is a minimal Node.js worker thread pool implementation. Prior to 2.1.2, Tinypool reads filename from a caller-supplied options object in pool.run(task, options) without requiring an own property, so a polluted Object.prototype.filename can replace the intended worker module. Applications are affected only when they pass their own second-argument options object to po...
CVE-2026-105080	New	9.4	CRIT				In ConvertX before 0.19.0, converters/calibre.ts does not block recipe files, and instead passes them to the ebook-convert program from Calibre. This affects executable code in a .recipe or .downloaded_recipe file.
CVE-2026-75937	New	9.4	CRIT				A specially crafted HTTP POST request to the web administration interface allows an unauthenticated attacker to execute arbitrary operating system commands with root privileges on the affected device. Disable the web server when not configuring the device.
CVE-2026-86325	New	9.4	CRIT				A stack-based buffer overflow vulnerability exists in protocol gateways' account management interface. The vulnerability is caused by insufficient length validation of the `account_name` parameter when processing account management requests. An attacker authenticated as a read-only user to the web management interface could supply a specially crafted account name that exceed...
CVE-2026-104019	New	9.3	CRIT				OS command injection in the Studio Space startup validation script in Amazon SageMaker Distribution 2.x before 2.14.12, 3.x before 3.9.12, 4.0.x before 4.0.11, 4.1.x before 4.1.11, 4.2.x before 4.2.8, 4.3.x before 4.3.5, and 4.4.x before 4.4.3, as used by Amazon SageMaker Unified Studio, might allow an authenticated remote user with project contributor permissions to execute...
CVE-2026-104610	New	9.3	CRIT				A security vulnerability has been detected in Tenda HG7, HG9 and HG10 300001138_en_xpon. This impacts the function boaGetVar of the file /boaform/formLoopBack of the component Boa Web Server. Such manipulation of the argument Ethtype leads to stack-based buffer overflow. The attack can be executed remotely. The exploit has been disclosed publicly and may be used.
CVE-2026-84411	New	9.3	CRIT				The web management service in affected RouterOS versions contains an integer underflow in its HTTP request body handling that is reachable before authentication. This can be leveraged by an unauthenticated network attacker to achieve arbitrary code execution as root, or to cause a denial of service, using a single crafted request.
CVE-2026-95102	New	9.3	CRIT				WebSocket endpoints lack proper authentication mechanisms, enabling attackers to impersonate charging stations. As a result, attackers can exploit this weakness to gain unauthorized access to sensitive data or perform unauthorized actions. Given that no authentication is required, this can lead to privilege escalation and potentially compromise the security of the entire sys...
CVE-2026-104467	New	9.2	CRIT				YesWiki before 4.6.7 contains an authorization bypass vulnerability in ApiService::isAuthorized() that allows unauthenticated attackers to call admin-only API routes when public API mode is enabled. Attackers can send requests to endpoints like api/ci/update_config and api/archives to overwrite configuration and list, download, or delete backup archives.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83632	New	9.2	CRIT				Allocation of resources without limits or throttling, Integer overflow or wraparound, Heap-based buffer overflow vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.25.0. Users are recommended to upgrade to version 0.25.0, which fixes the issue.
CVE-2026-91135	New	9.2	CRIT				Heap-based buffer overflow vulnerability in Apache Thrift C++ THeaderTransport. When an application enables the ZLIB transform for the frames it sends, THeaderTransport::transform() copies the compressed frame into the write buffer without making sure it fits. Data that does not compress, such as content a remote peer supplied, grows under compression, so the copy writes ...
CVE-2026-103648	New	9.1	CRIT				Path traversal in image-downloader 4.3.0 allows an attacker who can control the download URL to cause downloaded response data to be written outside the configured destination directory.
CVE-2026-63569	New	9.1	CRIT		0.004		Improper input validation in DHAgreement.CalculateAgreement (MTI/A0 two-pass Diffie-Hellman) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an on-path attacker to make the local party compute an agreed value the attacker already knows, defeating the key authentication MTI/A0 is meant to provide. It also allows a malicious peer to learn the local static pri...
CVE-2026-93029	New	9.0	CRIT		0.004		There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Manage SSL Hosts interface.
CVE-2026-93697	New	9.0	CRIT		0.004		There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Mass Modify Accounts interface.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.